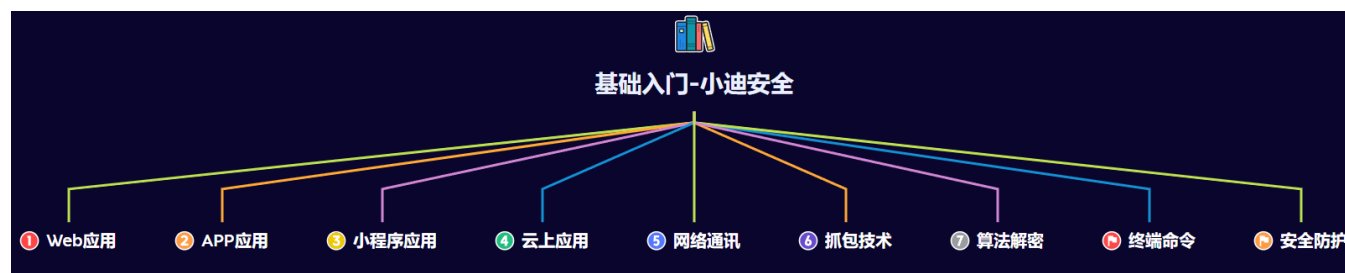


Day11 基础入门-算法解密&散列对称非对称&字典碰撞&前后端逆向&MD5&AES&DES&RSA



1.知识点

- 1、基础入门-Web应用-域名上的技术要点
- 2、基础入门-Web应用-源码上的技术要点
- 3、基础入门-Web应用-数据上的技术要点
- 4、基础入门-Web应用-解析上的技术要点

- 1、基础入门-Web应用-搭建架构上的技术要点
- 2、基础入门-Web应用-源码类别上的技术要点

- 1、基础入门-Web应用-防护产品-WAF保护
- 2、基础入门-Web应用-加速服务-CDN节点
- 3、基础入门-Web应用-文件托管-OSS存储
- 4、基础入门-Web应用-通讯服务-反向代理
- 5、基础入门-Web应用-运维安全-负载均衡

- 1、基础入门-Web应用-蜜罐系统
- 2、基础入门-Web应用-堡垒机运维
- 3、基础入门-Web应用-内外API接口
- 4、基础入门-Web应用-第三方拓展架构

- 1、基础入门-APP应用-开发架构安全问题
- 2、基础入门-小程序应用-开发架构安全问题

- 1、抓包技术-Web应用-http/s-Burp&Yakit
- 2、抓包技术-APP应用-http/s-Burp&Yakit

- 3、抓包技术-PC端应用-http/s-Burp&Yakit
 - 4、抓包技术-WX小程序-http/s-Burp&Yakit
 - 5、抓包技术-软件联动-http/s-Proxifier
 - 6、抓包技术-通用方案-http/s-ReqableApi
 - 7、抓包技术-其他工具-http/s-Fiddler&Charles
-

- 1、抓包技术-HTTP/S双层代理-扶墙环境
 - 2、抓包技术-HTTP/S上游下游-项目联动
 - 3、抓包技术-全局协议-WireShark&科来
-

- 1、数据不回显原因和解决-带外延迟反弹写文件
 - 2、数据不出网原因和解决-出入站策略正反向连接
-

- 1、反弹Shell-项目&命令&语言等
 - 2、系统渗透命令-网络&文件&操作等
-

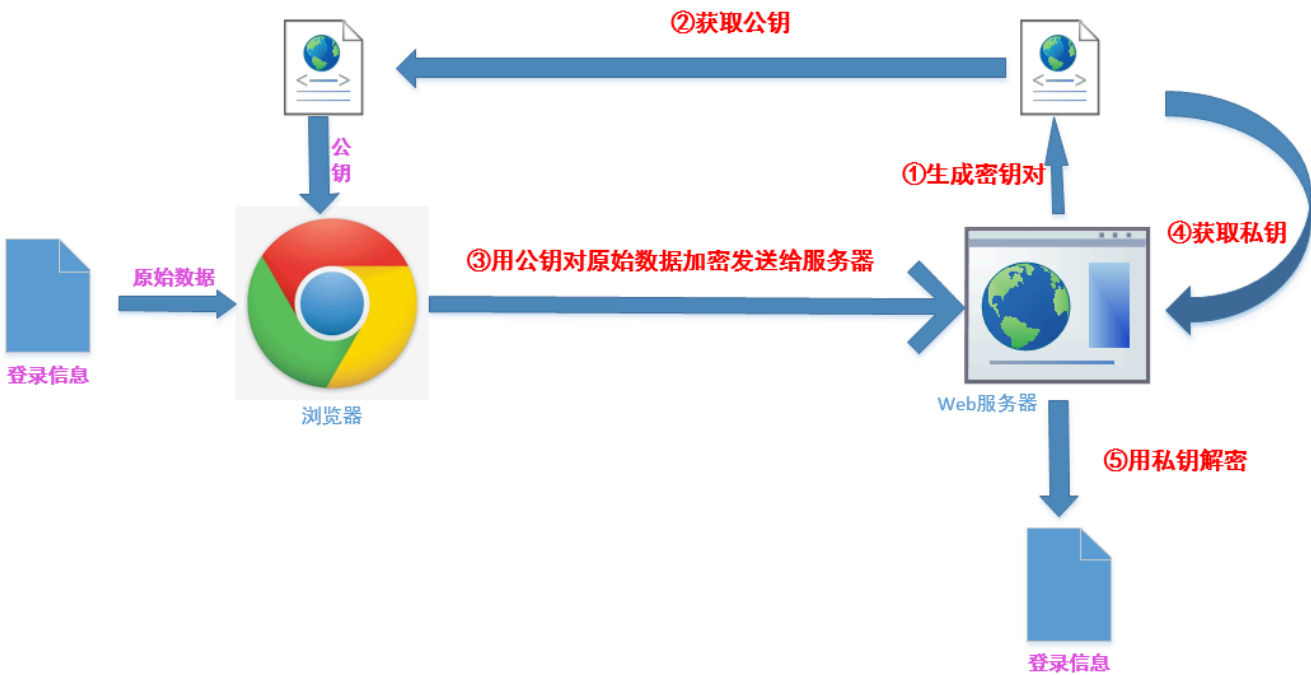
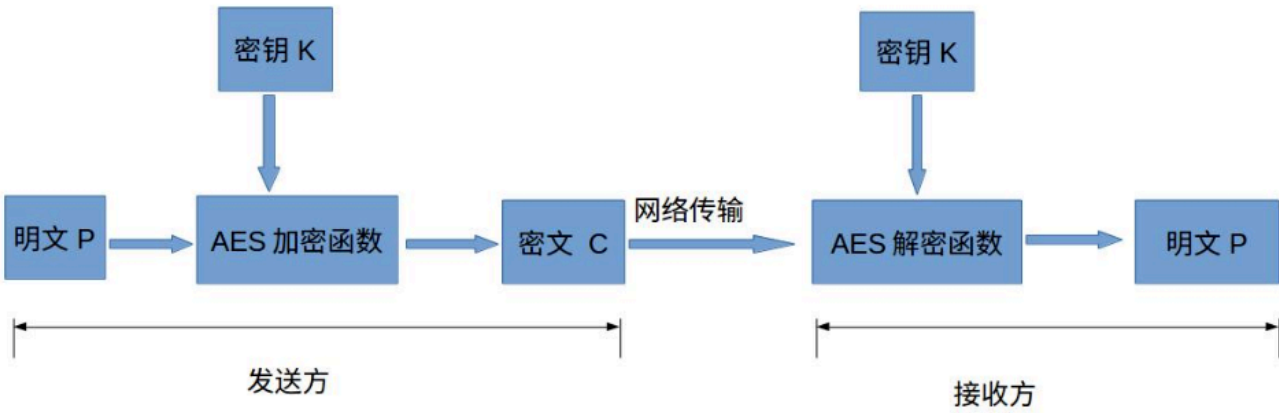
- 1、传输格式&数据-类型&编码&算法
 - 2、密码存储&混淆-不可逆&非对称性
-

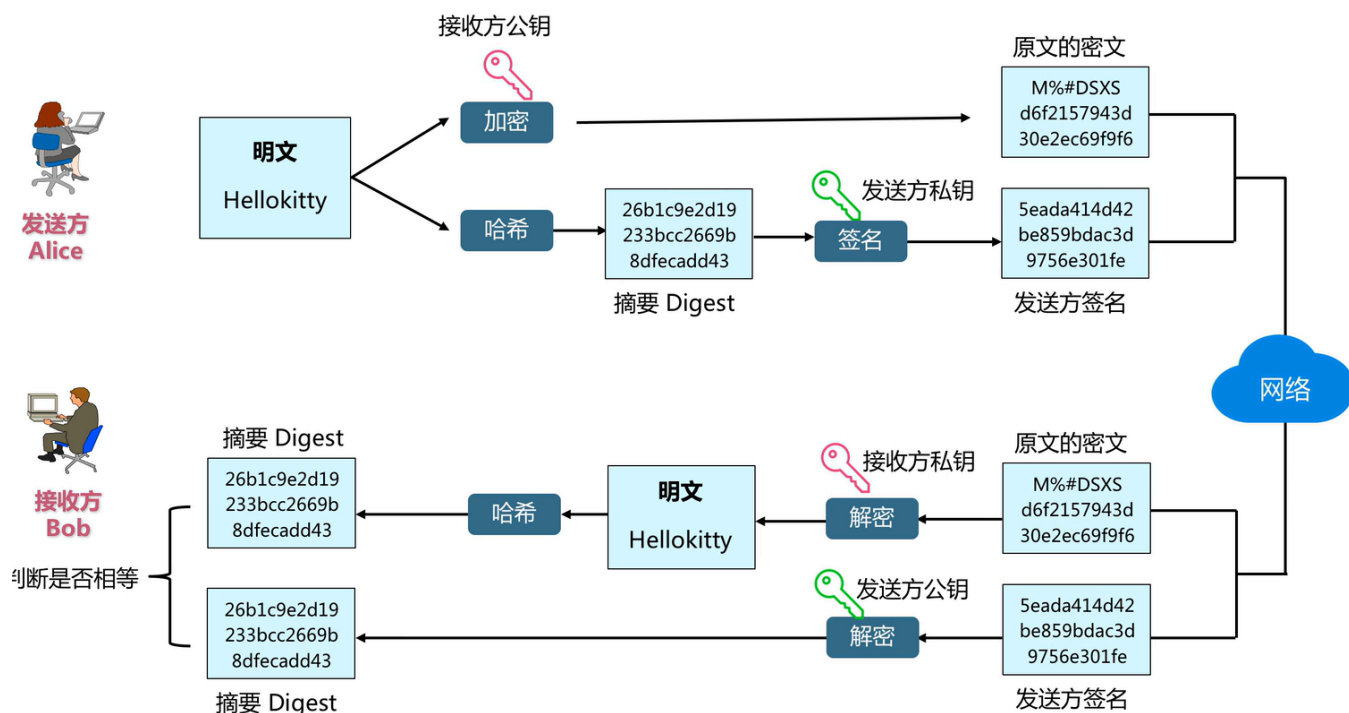
- 0、算法类型-单向散列&对称性&非对称性
 - 1、算法识别加解密-MD5&AES&DES&RSA
 - 2、解密条件寻找-逻辑特征&源码中&JS分析
-

2.详细点

- 架构：WEB,APP,小程序,前后端,容器化等
 - 服务：OSS存储,CDN加速,云数据库,负载均衡等
 - 网络：不回显,反向代理,防火墙出入站,内外网,正反向连接等
 - 算法：MD5,Base64,AES,DES,Salt,自定义,代码加密算法等
 - 命令：Windows&Linux,文件下载,网络查看,反弹权限,用户等
 - 防护：WAF防护,蜜罐系统,CDN加速,权限设置,加壳加密反调试等
-

3.演示案例





3.1 算法识别加解密-MD5&AES&DES&RSA



- 1 安全测试中:
- 2 密文-有源码直接看源码分析算法 (后端必须要有源码才能彻底知道)
- 3 密文-没有源码1、猜识别 2、看前端JS (加密逻辑是不是在前端)

3.1.1 MD5



- 1 1. 单向散列加密 -MD5
- 2 单向散列加密算法的优点有(以MD5为例):
- 3 方便存储, 损耗低: 加密/解密对于性能的损耗微乎其微。
- 4 单向散列加密的缺点就是存在暴力破解的可能性, 最好通过加盐值的方式提高安全性, 此外可能存在散列冲突。我们都知MD5加密也是可以破解的。
- 5 常见的单向散列加密算法有:
- 6 MD5 SHA MAC CRC
- 7 *解密条件: 密文即可, 采用碰撞解密, 几率看明文复杂程度



- 1 MD5密文特点:
- 2 1、由数字“0-9”和字母“a-f”所组成的字符串
- 3 2、固定的位数 16 和 32位
- 4 解密需求: 密文即可, 但复杂明文可能解不出



- 1 1、密码存储 (后端处理)
- 2 x3.2-md5&salt
- 3 DZ对应代码段-uc_server/model/user.php
- 4 function add_user() {


```

5         $password = md5(md5($password).$salt);
6     }
7
8     <?PHP
9     $h = 'd7192407bb4bfc83d28f374b6812fbcd';
10    $hash=md5(md5('123456').'3946d5');
11    if($h==$hash){
12        echo 'ok';
13    }else{
14        echo 'no';
15    }
16    ?>

```

```

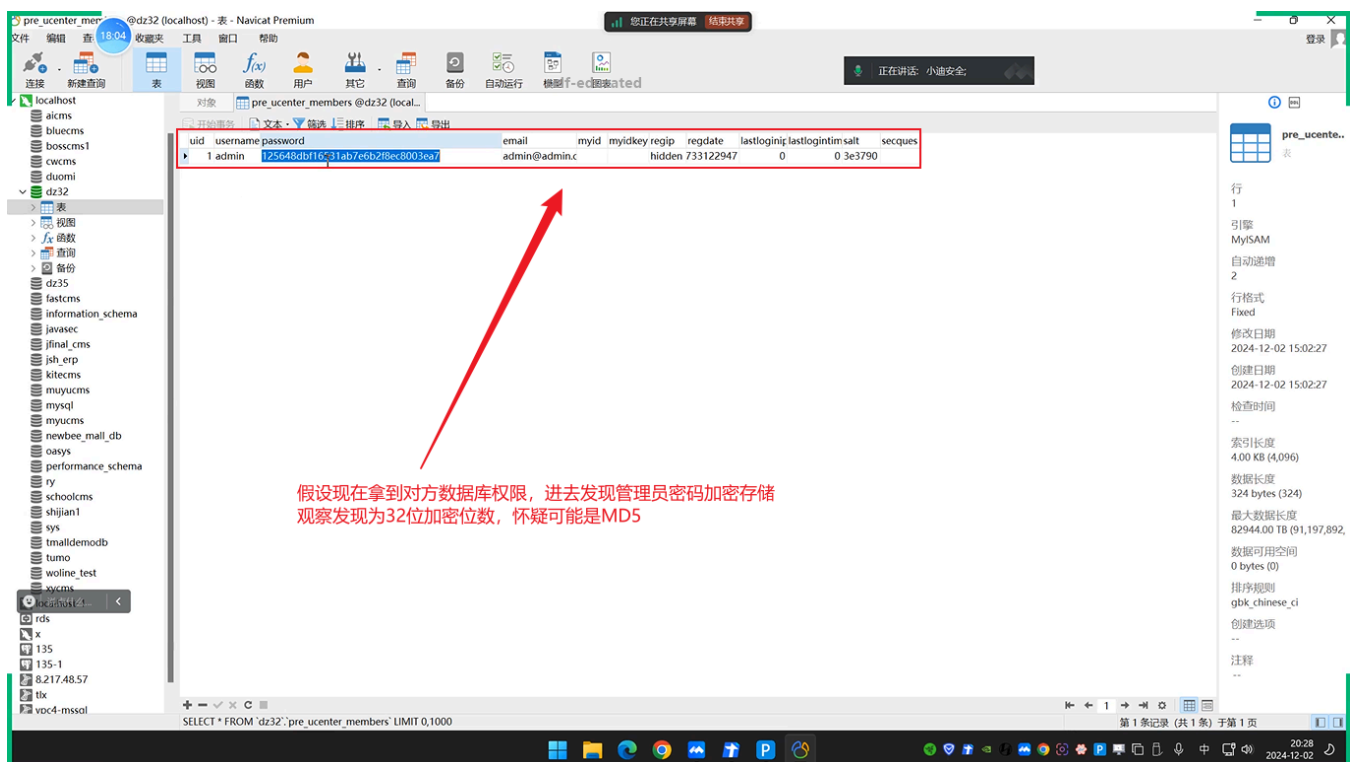
1  <?php
2  function reverse_md5_hash_with_salt($final_hash, $salt, $dictionary_file) {
3      // 打开字典文件
4      $file = fopen($dictionary_file, "r");
5      if (!$file) {
6          die("无法打开字典文件!");
7      }
8
9      // 遍历字典文件中的每一行（即每一个密码）
10     while (($password = fgets($file)) !== false) {
11         // 去除密码两侧的空白字符（包括换行符）
12         $password = trim($password);
13
14         // 第一次 MD5 加密密码
15         $md5_hash = md5($password);
16
17         // 拼接 md5($password) 和 salt
18         $salted_hash = $md5_hash . $salt;
19
20         // 第二次 MD5 加密
21         $final_attempt = md5($salted_hash);
22
23         // 检查是否匹配
24         if ($final_attempt === $final_hash) {
25             fclose($file);
26             return $password; // 找到匹配的密码
27         }
28     }
29
30     // 如果没有找到匹配的密码
31     fclose($file);
32     return null;
33 }

```

```

34
35 // 给定的目标加密值和盐值
36 $final_hash = "125648dbf16531ab7e6b2f8ec8003ea7"; // 目标 MD5 值
37 $salt = "3e3790"; // 盐值
38
39 // 字典文件路径
40 $dictionary_file = "weaksauce.txt"; // 字典文件路径
41
42 // 调用函数进行密码破解
43 $password = reverse_md5_hash_with_salt($final_hash, $salt, $dictionary_file);
44
45 // 输出结果
46 if ($password) {
47     echo "破解成功, 密码是: $password";
48 } else {
49     echo "密码破解失败";
50 }
51 ?>

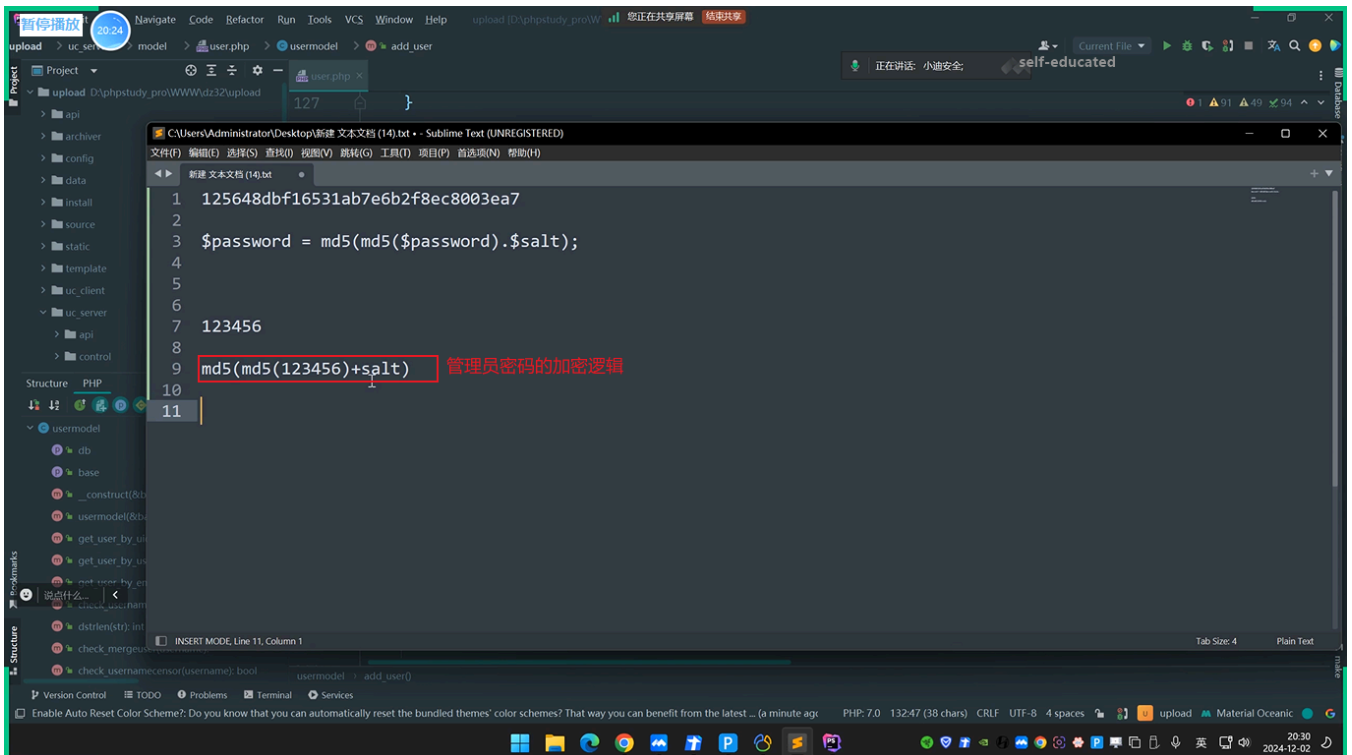
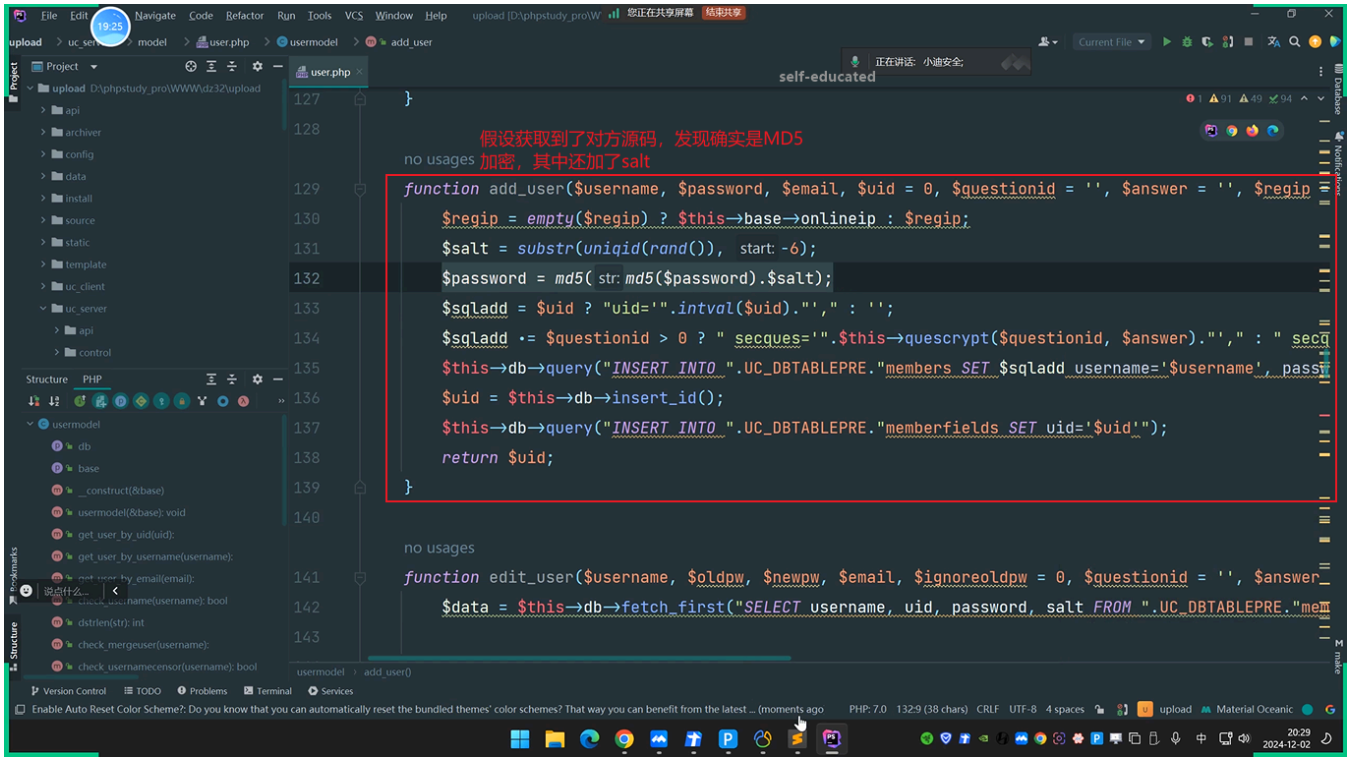
```

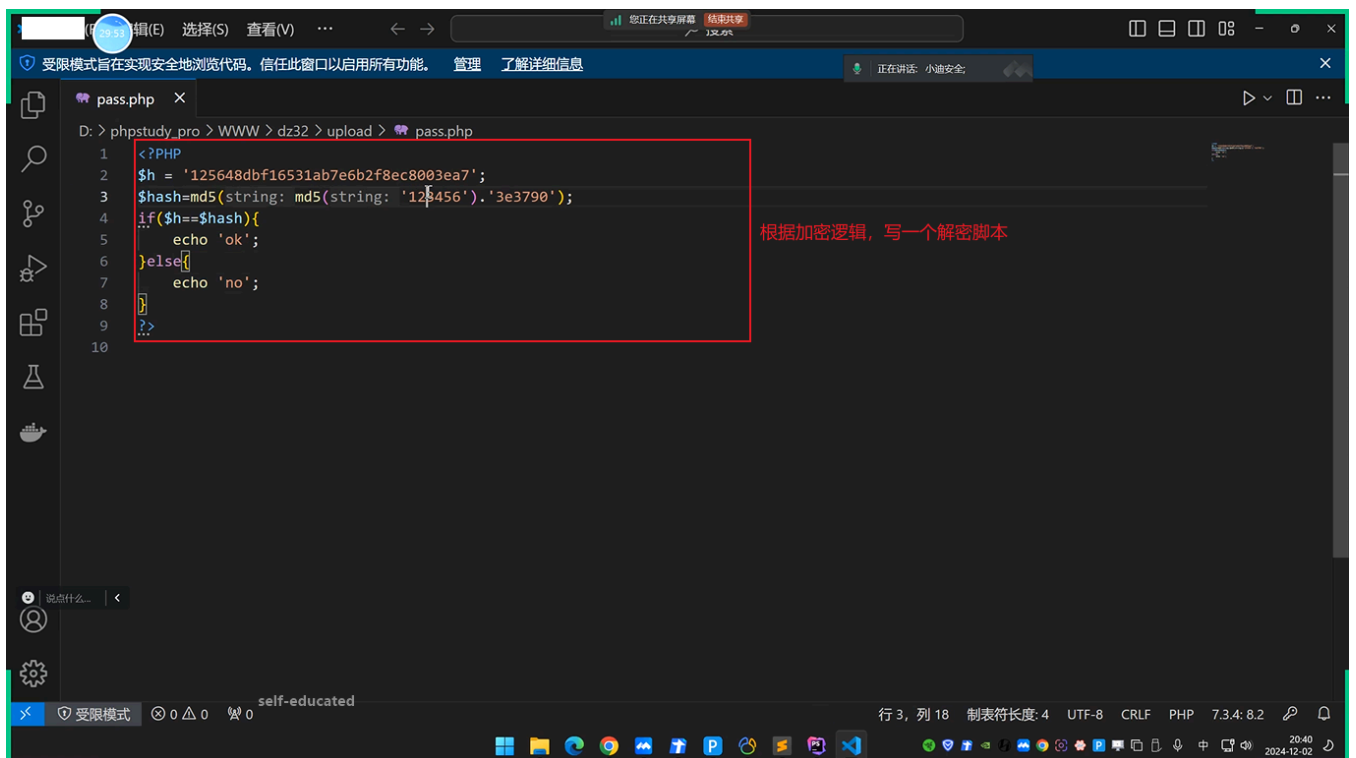
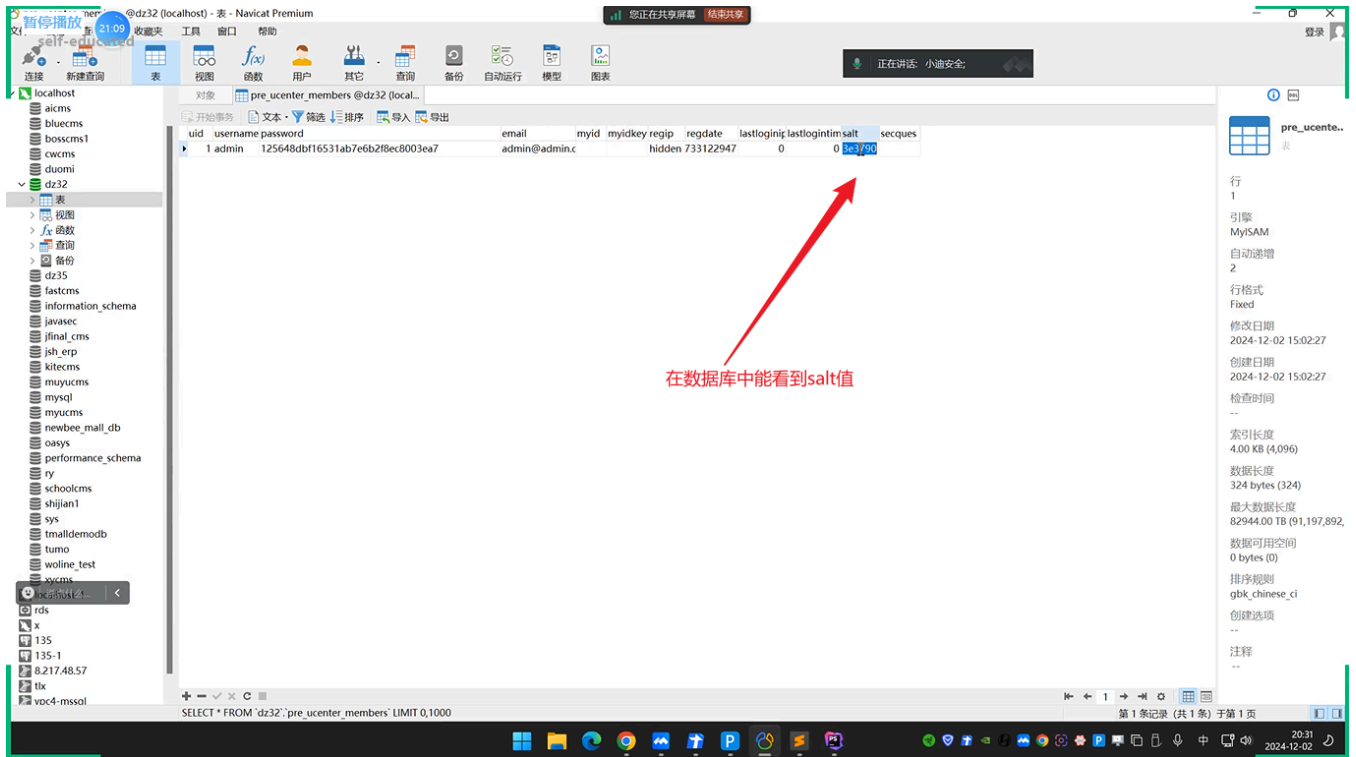


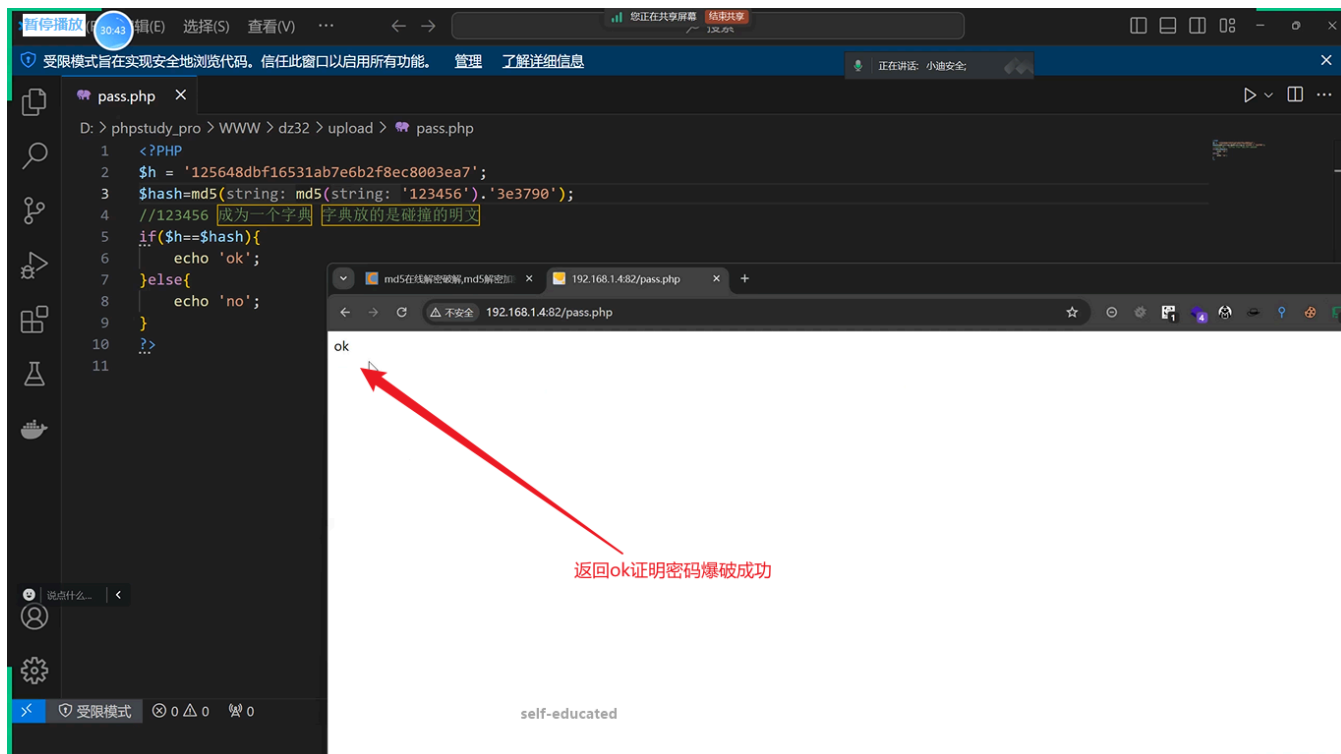
假设现在拿到对方数据库权限, 进去发现管理员密码加密存储
观察发现为32位加密位数, 怀疑可能是MD5

uid	username	password	email	myid	myidkey	regip	regdate	lastloginip	lastlogintime	salt	secques
1	admin	125648dbf16531ab7e6b2f8ec8003ea7	admin@admin.c			hidden	733122947		0	0	3e3790

SELECT * FROM 'dz32'.'pre_ucenter_members' LIMIT 0,1000







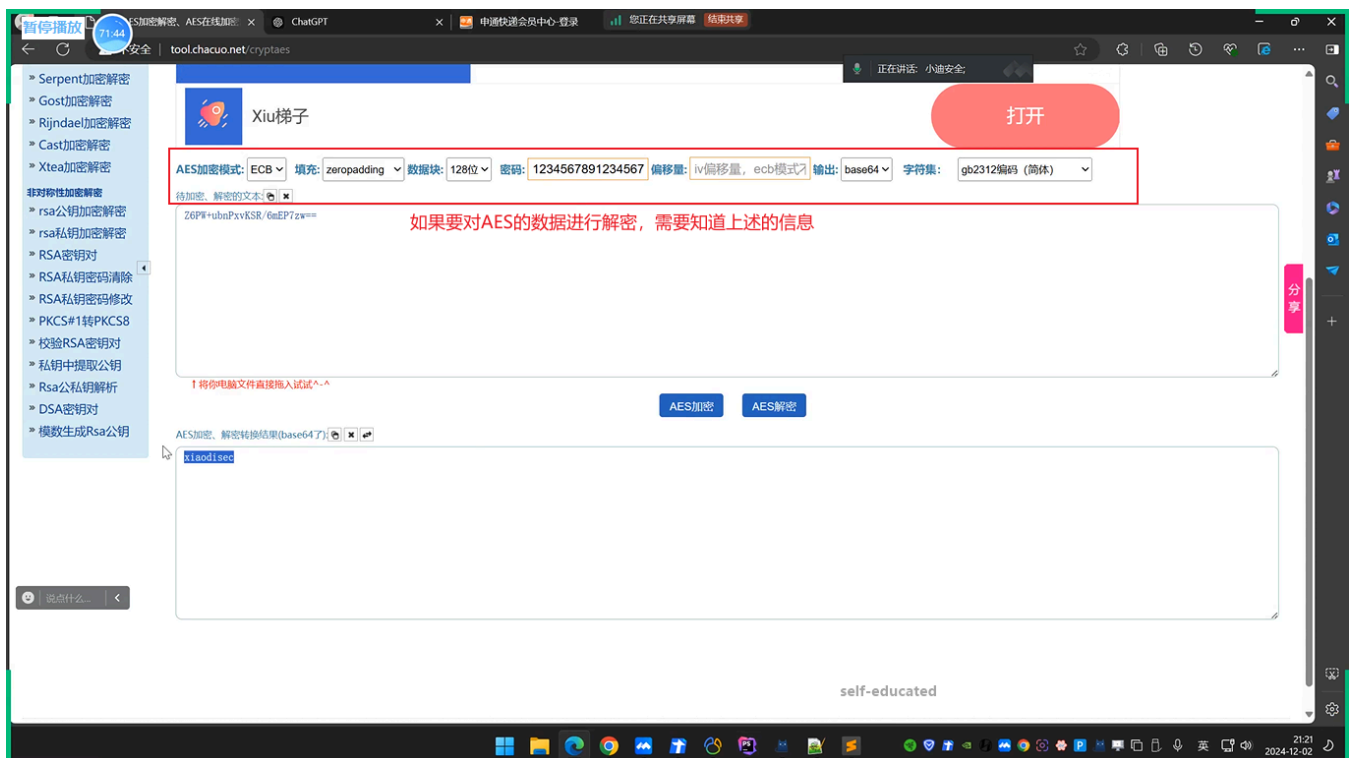
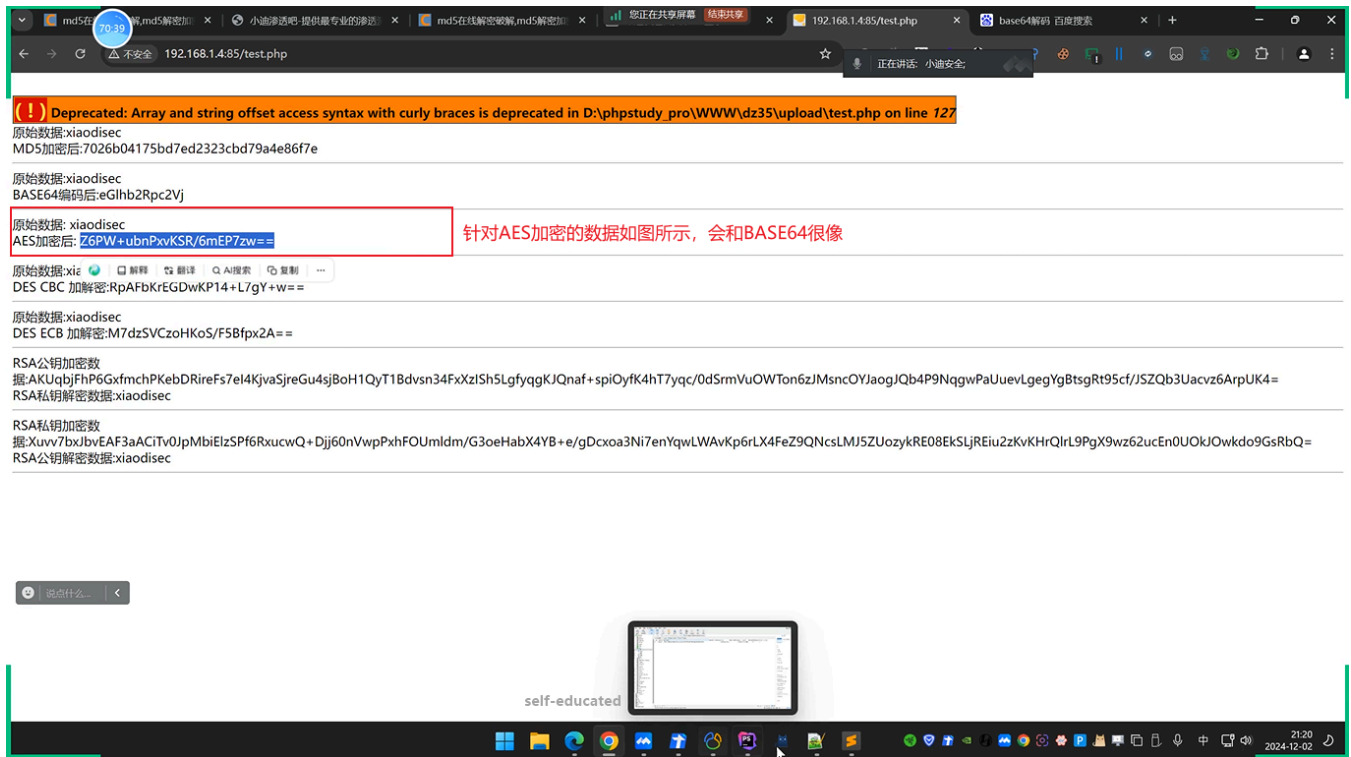
3.1.2 AES



2. 对称加密 -AES
- 对称加密优点是算法公开、计算量小、加密速度快、加密效率高。
- 缺点是发送方和接收方必须商定好密钥，然后使双方都能保存好密钥，密钥管理成为双方的负担。
- 常见的对称加密算法有：
- DES AES RC4
- *解密条件：密文及密钥偏移量，采用逆向算法解密，条件成立即可解密成功



- AES、DES密文特点：
- 同BASE64基本类似，但一般会出现"/"和"+"在密文中
- 解密需求：密文，模式，加密key，偏移量，条件满足才可解出



3.1.3 RSA

3. 非对称加密 - RSA
- 非对称加密的优点是与对称加密相比, 安全性更好, 加解密需要不同的密钥, 公钥和私钥都可进行相互的加解密。
- 缺点是加密和解密花费时间长、速度慢, 只适合对少量数据进行加密。
- 常见的非对称加密算法:
- RSA RSA2 PKCS
- *解密条件: 密文和公钥或私钥, 采用逆向算法解密, 条件成立即可解密成功

- 1 RSA密文特点:
- 2 特征同AES,DES相似,但是长度较长
- 3 解密需求:密文,公钥或私钥即可解出

192.168.1.4:85/test.php

Deprecatd: Array and string offset access syntax with curly braces is deprecated in D:\phpstudy_pro\WWW\dz35\upload\test.php on line 127

原始数据:xiaodisec
MD5加密后:7026b04175bd7ed2323cbd79a4e86f7e

原始数据:xiaodisec
BASE64编码后:eGhhb2Rpc2Vj

原始数据: xiaodisec
AES加密后: Z6PW+ubnPvxKSR/6mEP7zw==

原始数据:xiaodisec
DES CBC 加密后:RpAfBKrEGDwKP14+L7gY+w==

原始数据:xiaodisec
DES ECB 加密后:M7dzSVCzoHKoS/F5Bfpx2A==

RSA公钥加密数据:AKUqbjFhP6GxfmchPkebDRireFs7eI4KjvaSjreGu4sjBoH1QyT1Bdvsn34FxXzIsh5LgfyqgKJQnaf+spiOyK4hT7yqc/0dSrmVuOWTon6zJMsncOYJaogJQb4P9NqgwPaUuevLgegYgBtsgrt95cf/JSZQb3Uacvz6ArpUK4=
RSA私钥解密数据:xiaodisec

RSA私钥解密数据: Xuvv7bxJbvEAF3aACitV0jPmBiElzSPf6RxcuqQ+Djj60nVwpPxfFOUldm/G3oeHabX4YB+e/gDcxoa3Ni7enYqWlWAvKp6rLX4FeZ9QNcsLMJ5ZUozykRE08EKSLjREiu2zKvKHrQlrL9PgX9wz62ucEn0UOkOwkdo9GsRbQ=
RSA公钥解密数据:xiaodisec

针对RSA用公钥和私钥加密得到的数据不一致

说点什么...



tool.chacuo.net/cryptasprkey

正在讲话: 小迪安全

针对公钥加密的数据, 使用私钥进行解密

填充方式: PKCS1_PADDING 私钥密码: 有密码才需 长文本: 支持超长文本 输出类型: base64 超长分隔字符: 字符集: gb2312编码

输入加密私钥 (以 "-----BEGIN PRIVATE KEY-----" 开头 "-----END PRIVATE KEY-----" 结尾)

AKUqbjFhP6GxfmchPkebDRireFs7eI4KjvaSjreGu4sjBoH1QyT1Bdvsn34FxXzIsh5LgfyqgKJQnaf+spiOyK4hT7yqc/0dSrmVuOWTon6zJMsncOYJaogJQb4P9NqgwPaUuevLgegYgBtsgrt95cf/JSZQb3Uacvz6ArpUK4=

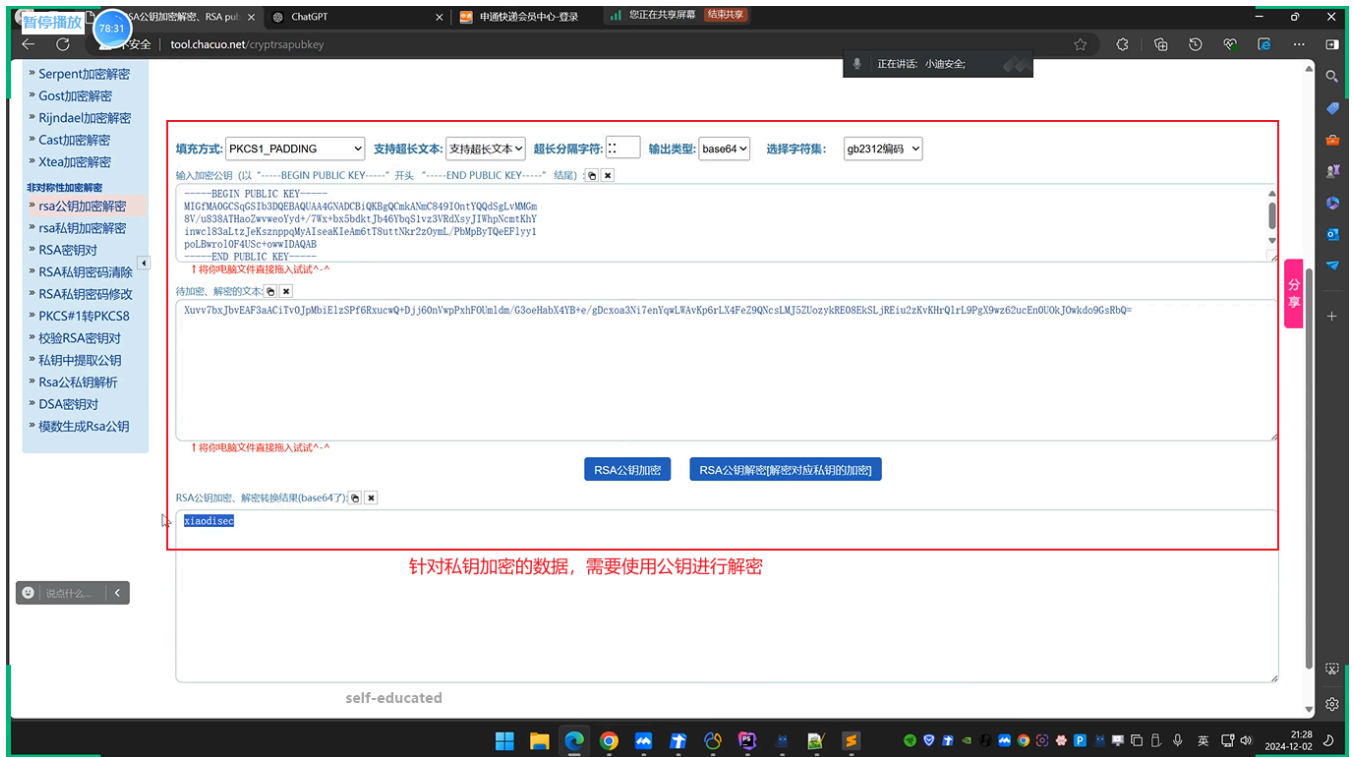
待加密、解密的文本:

↑ 将你的电脑文件直接拖入试试 ^-^

RSA私钥加密 RSA私钥解密(解密对应公钥的加密)

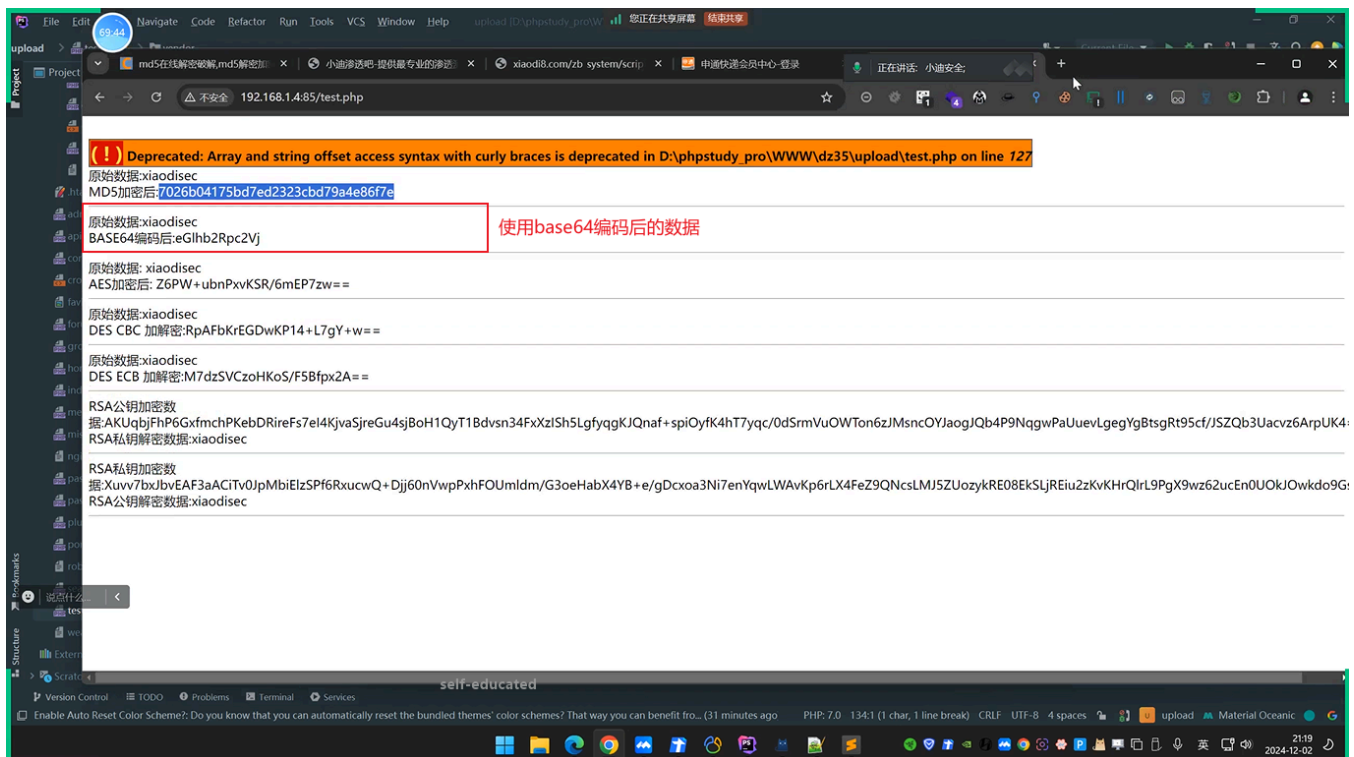
RSA私钥解密、解密转换结果(base64): xiaodisec

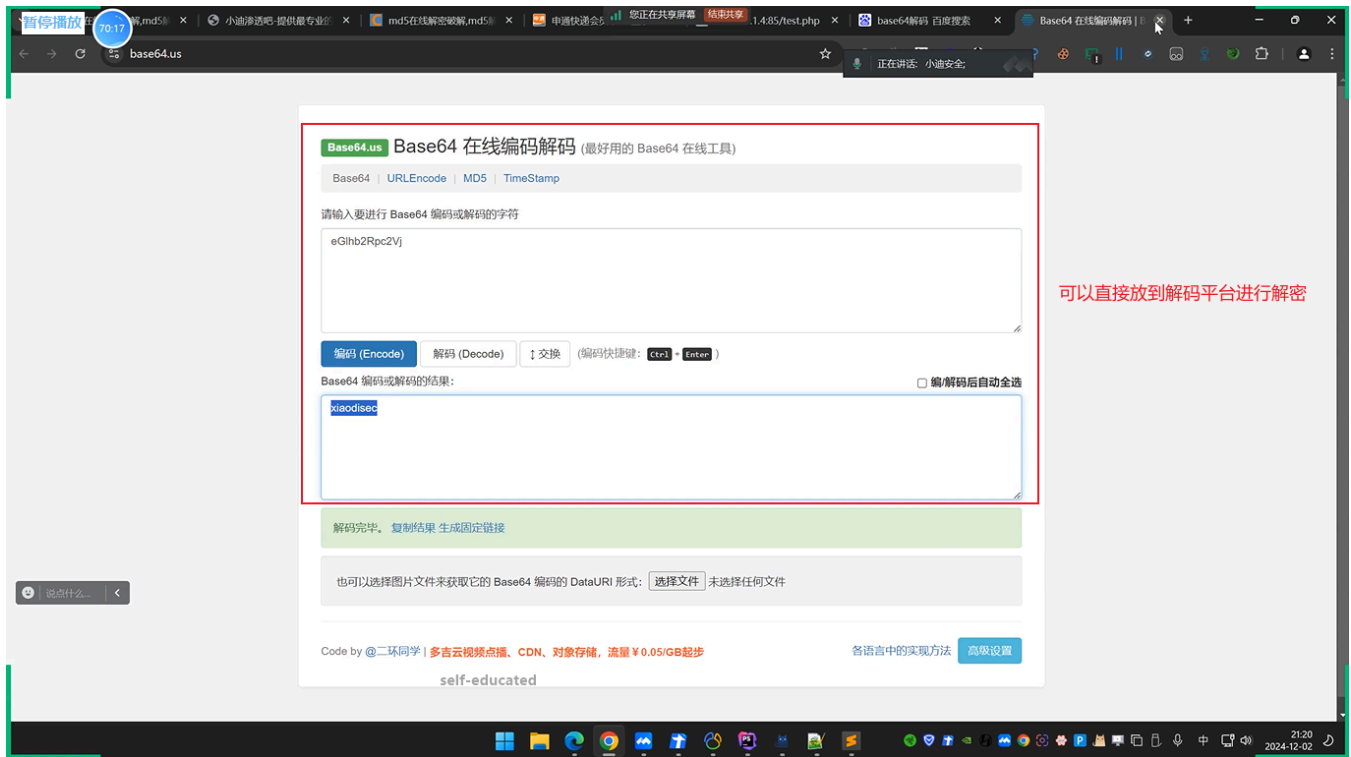




3.1.4 BASE64

4. BASE64编码特点:
- 0、大小写区分, 通过数字和字母的组合
- 1、一般情况下密文尾部都会有两个等号, 明文很少的时候则没有
- 2、明文越长密文越长, 一般不会出现"/""+"在密文中





3.1.5 其他

5. 其他密文特点见:
1. 30余种加密编码类型的密文特征分析 (建议收藏)
- https://mp.weixin.qq.com/s?__biz=MzAwNDcxMjI2MA==&mid=2247484455&idx=1&sn=e1b4324ddcf7d6123be30d9a5613e17b&chksm=9b26f60cac517f1a920cf3b73b3212a645aeeef78882c47957b9f3c2135cb7ce051c73fe77bb2&mpshare=1&scene=23&srcid=1111auAYWmr1N0NAS9Wp2hGz&sharer_sharetime=1605145141579&sharer_shareid=5051b3eddbbe2cb698aedf9452370026#rd
2. CTF中常见密码题解密网站总结 (建议收藏)
- https://blog.csdn.net/qq_41638851/article/details/100526839
3. CTF密码学常见加密解密总结 (建议收藏)
- https://blog.csdn.net/qq_40837276/article/details/83080460

3.2 解密条件-有源码找逻辑&无源码JS逆向

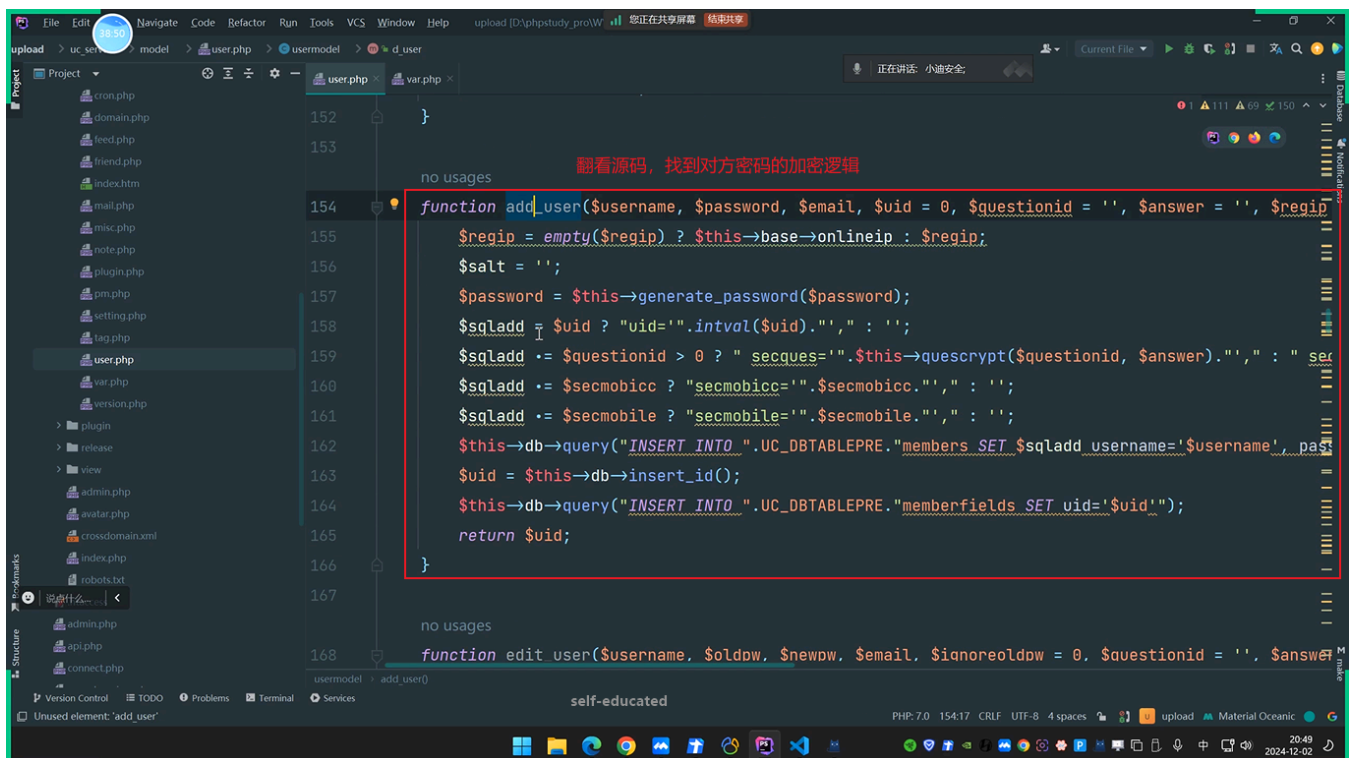
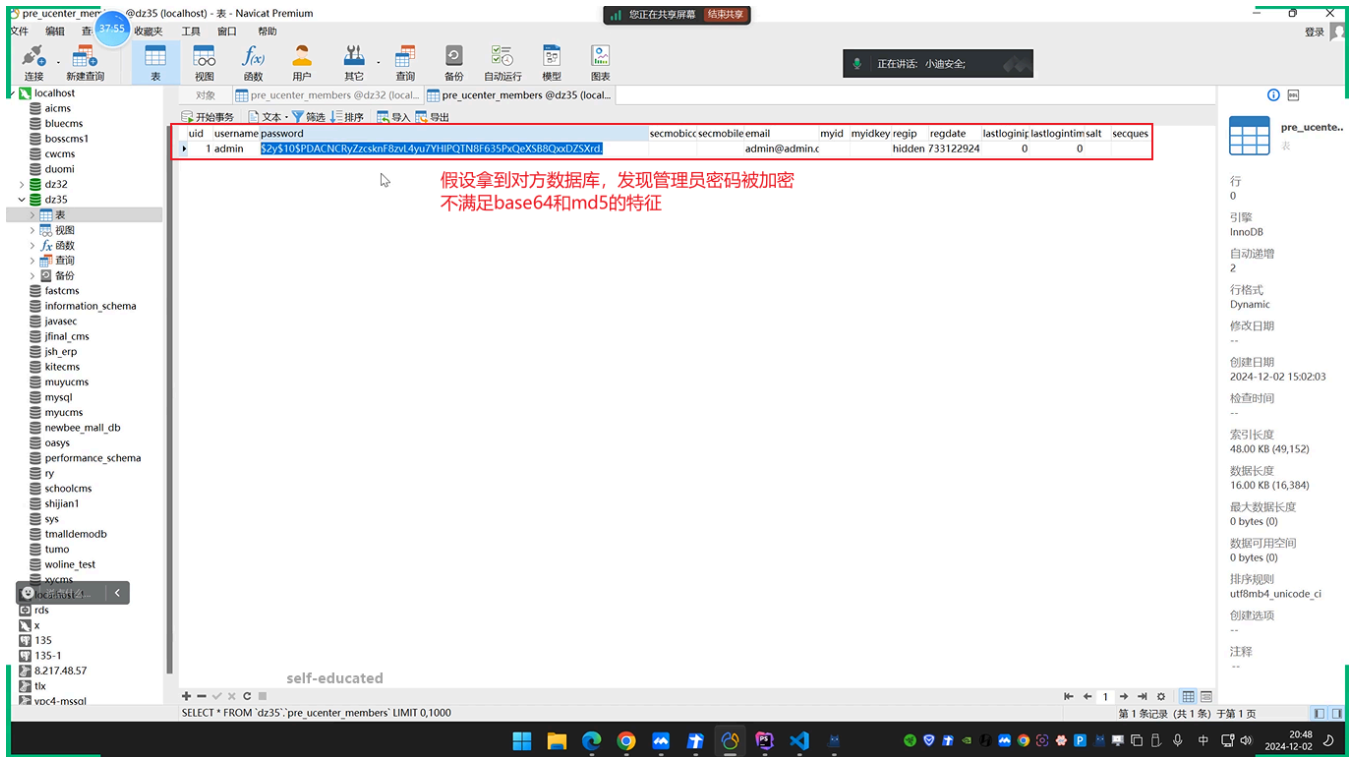
3.1.1 有源码找逻辑

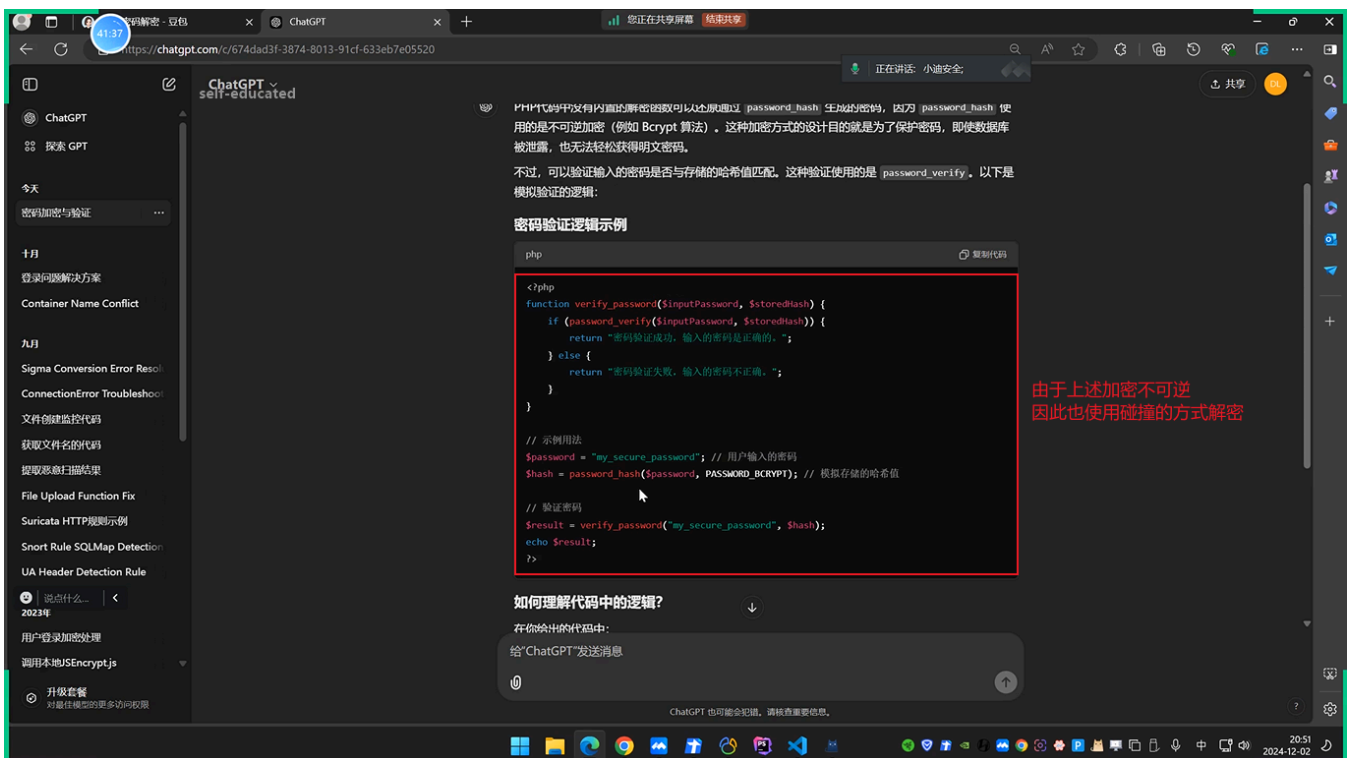
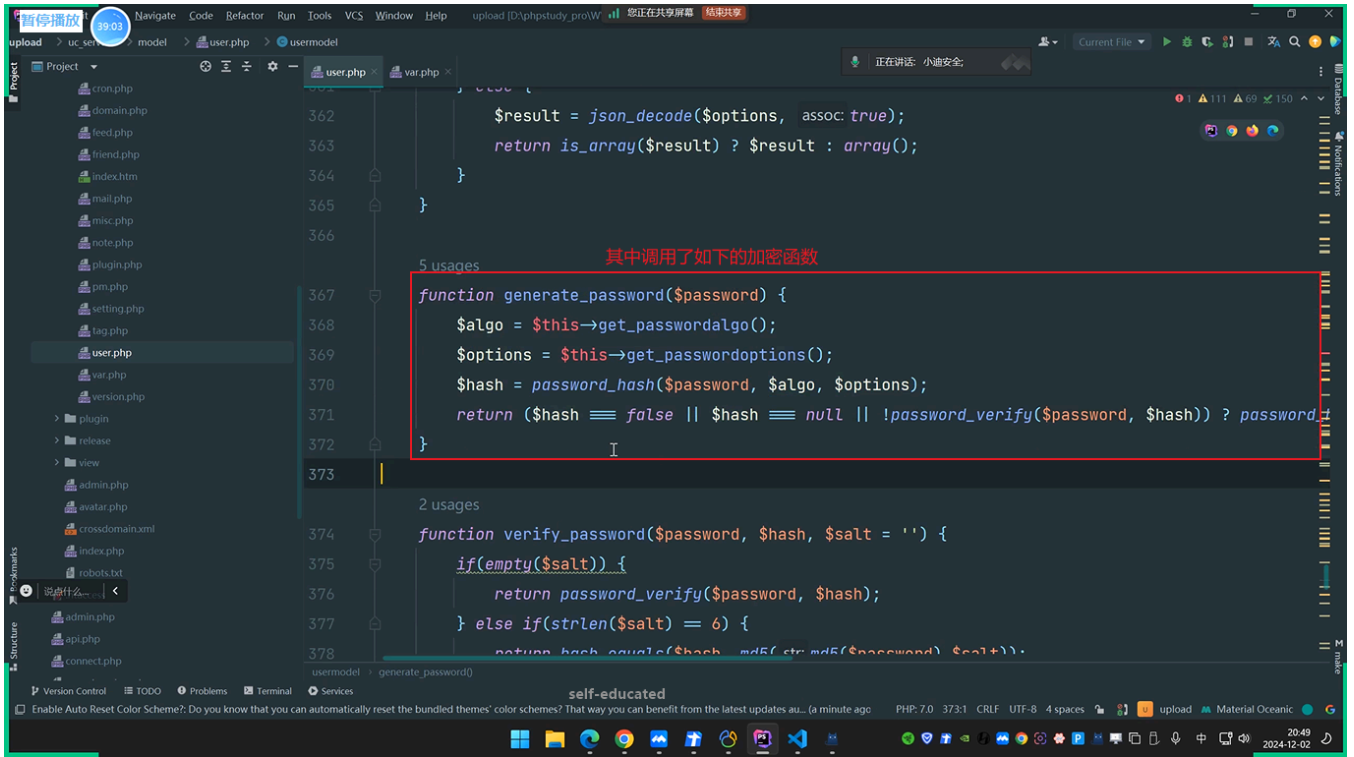
```
1 x3.5-hash
2 DZ对应代码段-/uc_server/model/user.php
3     function add_user() {
4         $salt = '';
5         $password = $this->generate_password($password);
6     }
7
8     function generate_password($password) {
```

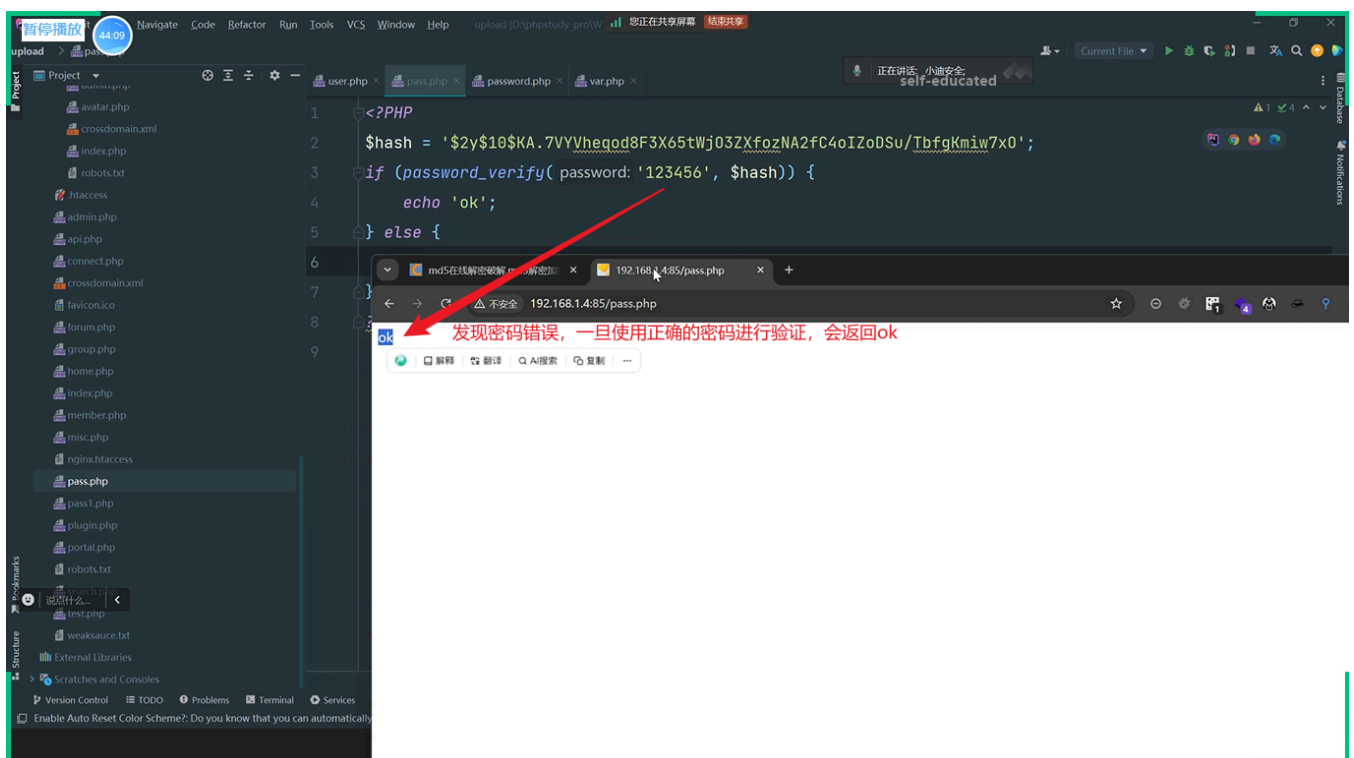
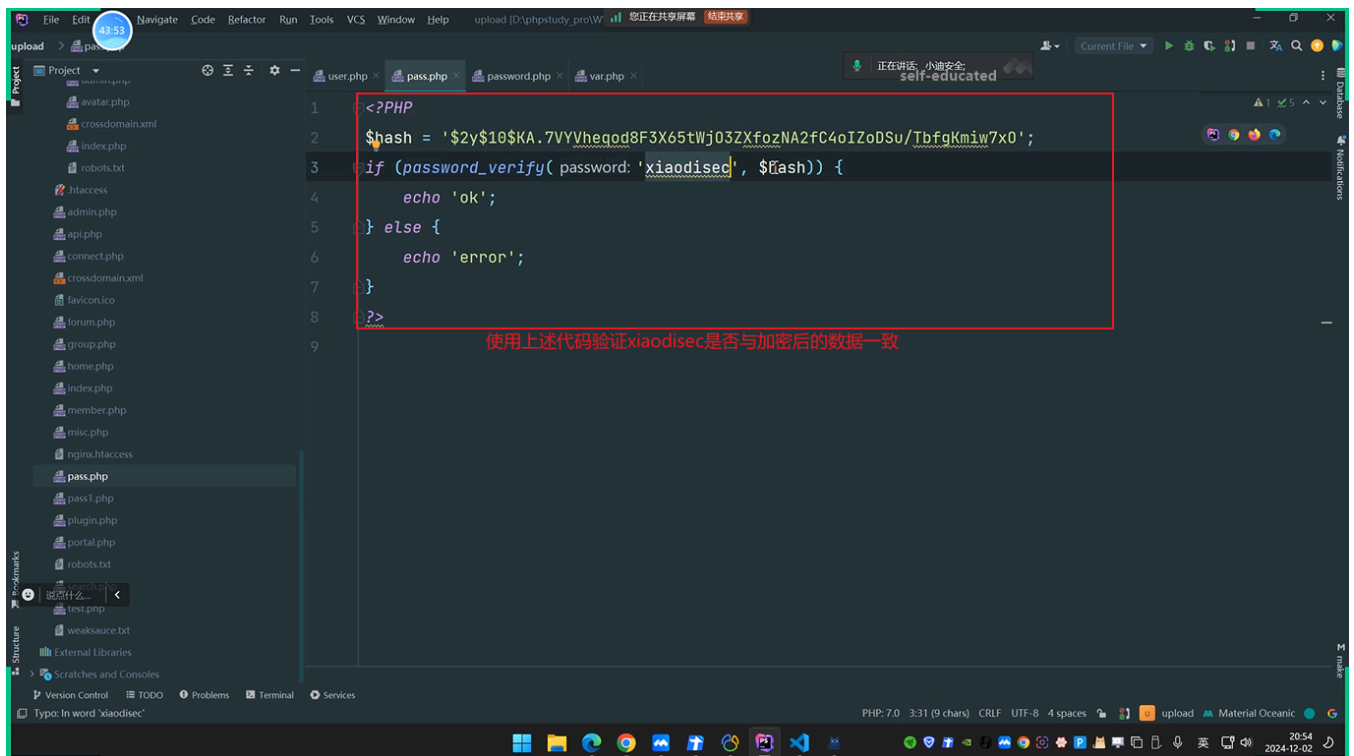
```
9         $algo = $this->get_passwordalgo();
10        $options = $this->get_passwordoptions();
11        $hash = password_hash($password, $algo, $options);
12    }
```

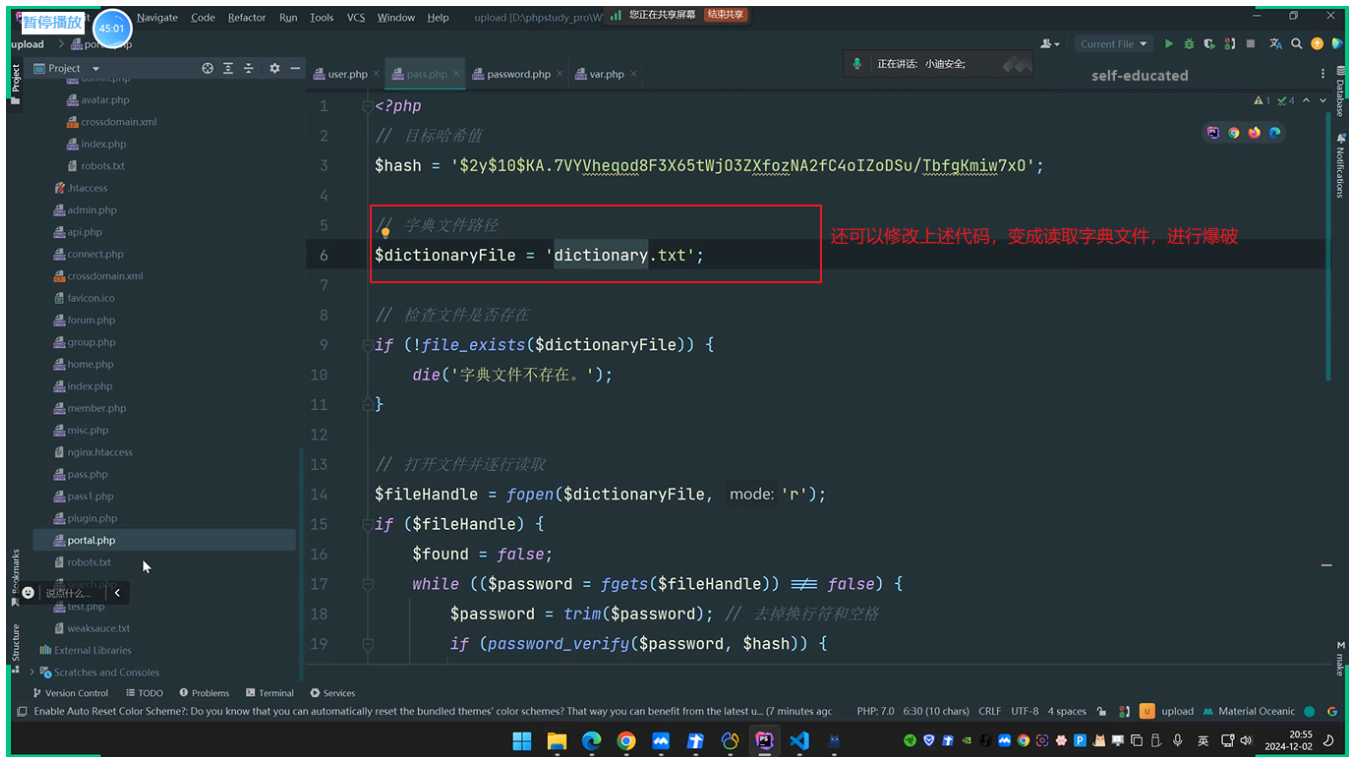
```
1  <?PHP
2  $hash = '$2y$10$KA.7VYVheqod8F3X65twj03ZXfozNA2fC4oIZoDSu/TbfgKmiw7x0';
3  if (password_verify('123456', $hash)) {
4      echo 'ok';
5  } else {
6      echo 'error';
7  }
8  ?>
```

```
1  <?PHP
2  $hash = '$2y$10$PDACNCryZzcsknF8zVL4yu7YHIPQTN8F635PxQeXSB8QxxDZSXrd.';
3
4  $dictionary_file = "weaksauce.txt";
5  $file = fopen($dictionary_file, "r");
6  if (!$file) {
7      die("无法打开字典文件!");
8  }
9
10 // 遍历字典文件中的每一行（即每一个密码）
11 while (($password = fgets($file)) !== false) {
12     // 去除密码两侧的空白字符（包括换行符）
13     $password = trim($password);
14     echo $password."<br>";
15
16     if (password_verify($password, $hash)) {
17         echo 'ok';
18     } else {
19         echo 'error';
20     }
21 }
22 ?>
```







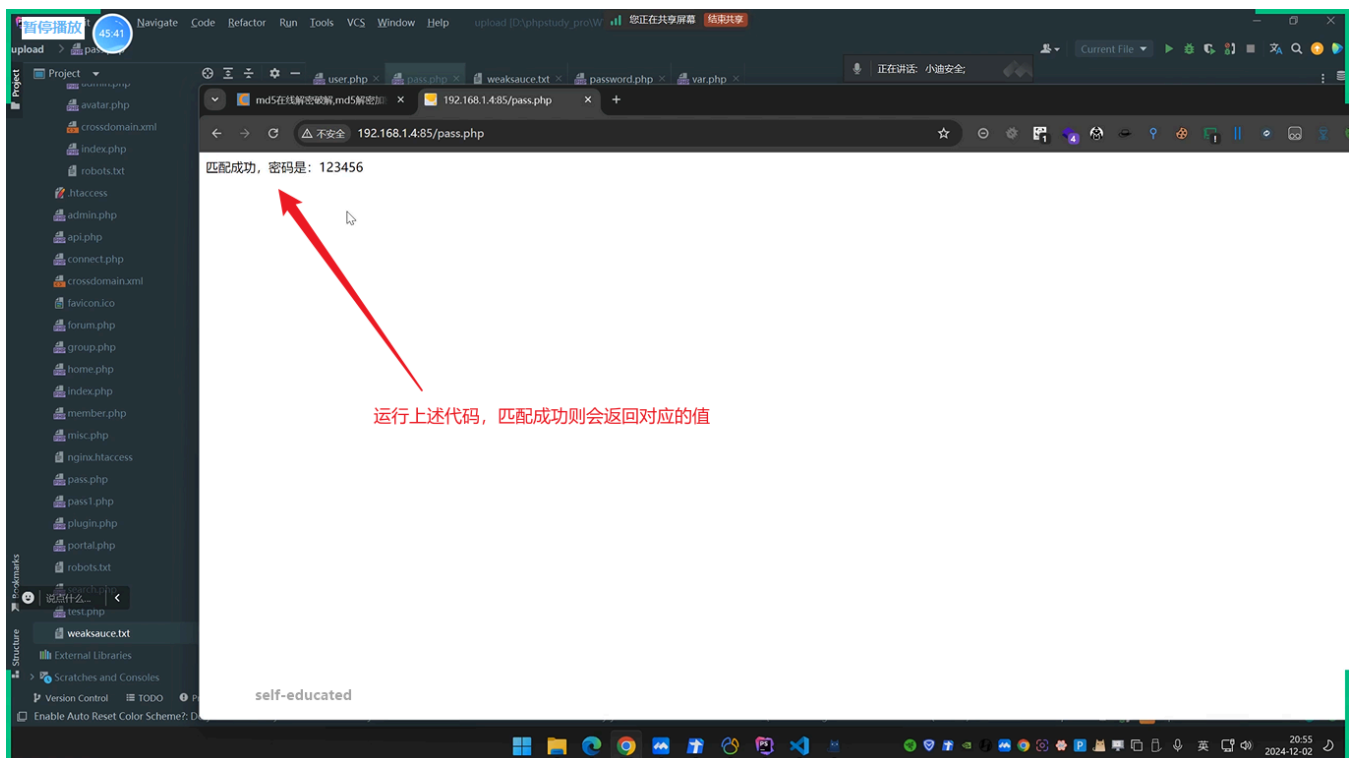


```
<?php
// 目标哈希值
$hash = '$2y$10$KA.7VYVheqod8F3X65tWj03ZXfozNA2fC4oIZoDSu/TbfgKmiw7x0';

// 字典文件路径
$dictionaryFile = 'dictionary.txt';

// 检查文件是否存在
if (!file_exists($dictionaryFile)) {
    die('字典文件不存在。');
}

// 打开文件并逐行读取
$fileHandle = fopen($dictionaryFile, mode: 'r');
if ($fileHandle) {
    $found = false;
    while (($password = fgets($fileHandle)) !== false) {
        $password = trim($password); // 去掉换行符和空格
        if (password_verify($password, $hash)) {
```



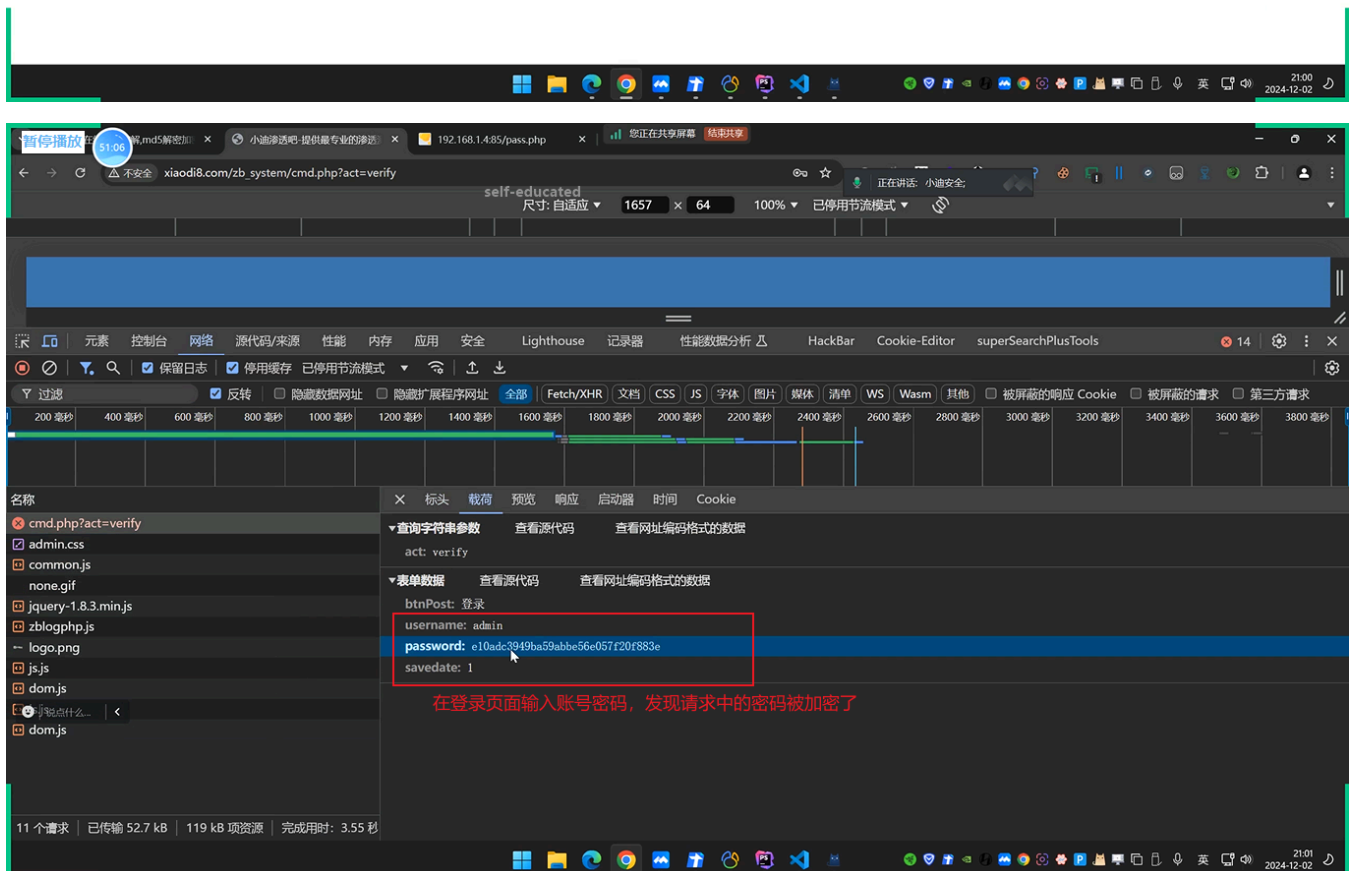
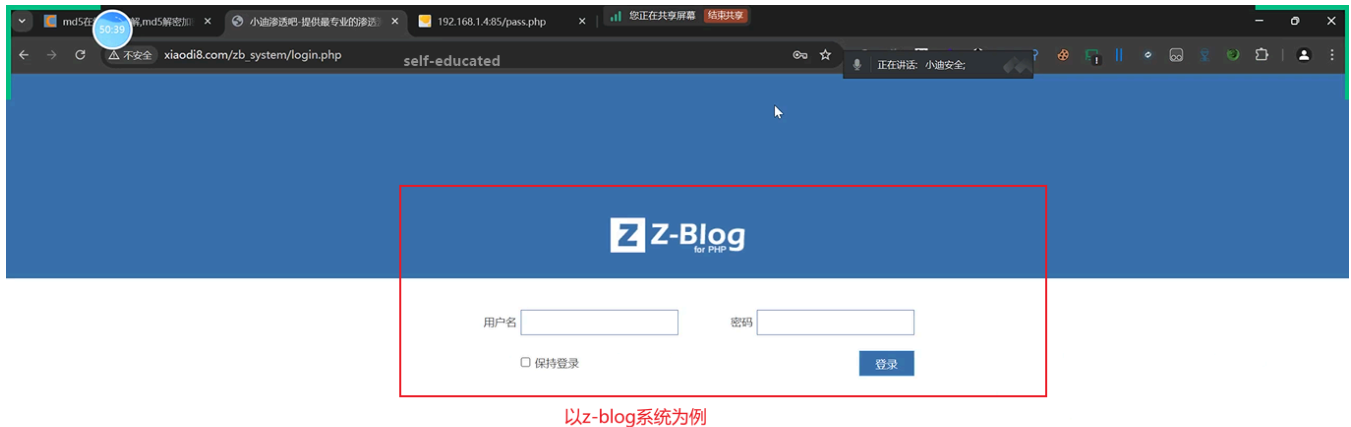
匹配成功, 密码是: 123456

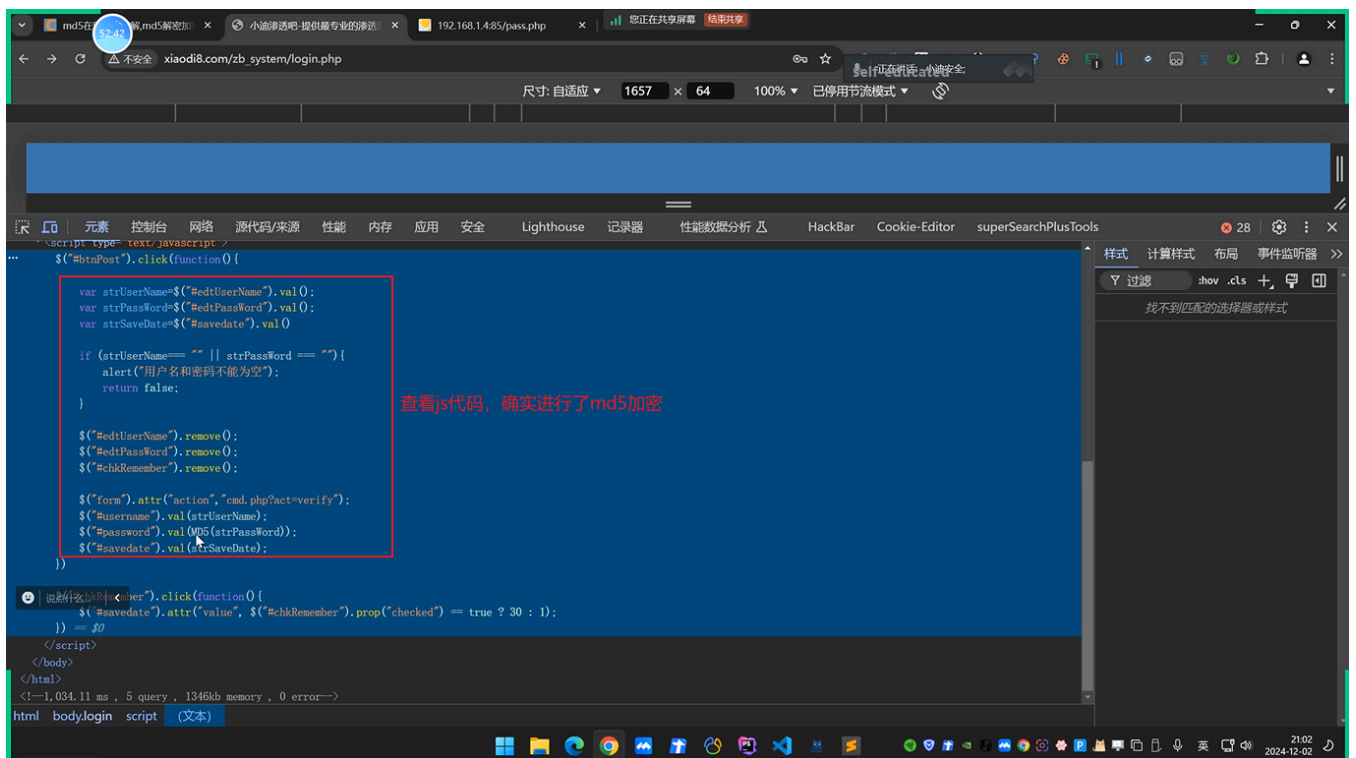
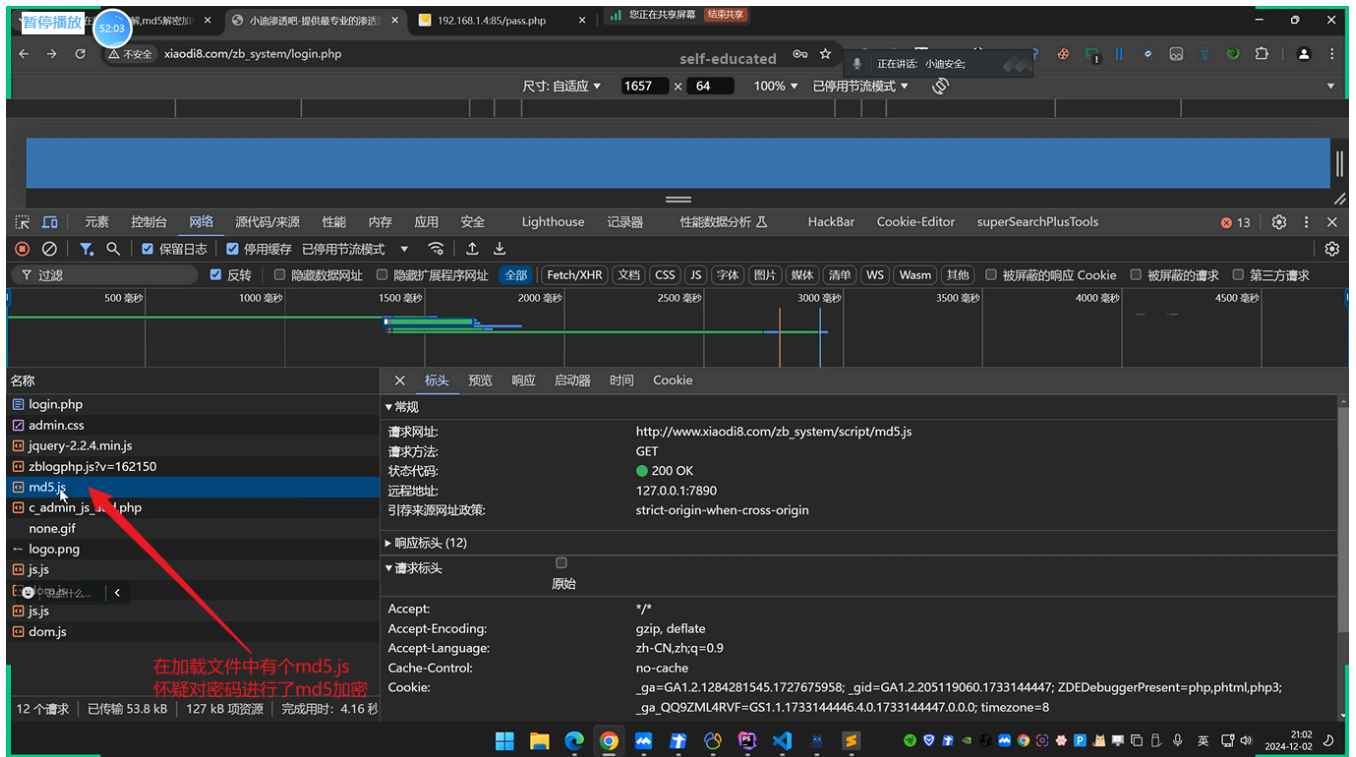
运行上述代码，匹配成功则会返回对应的值

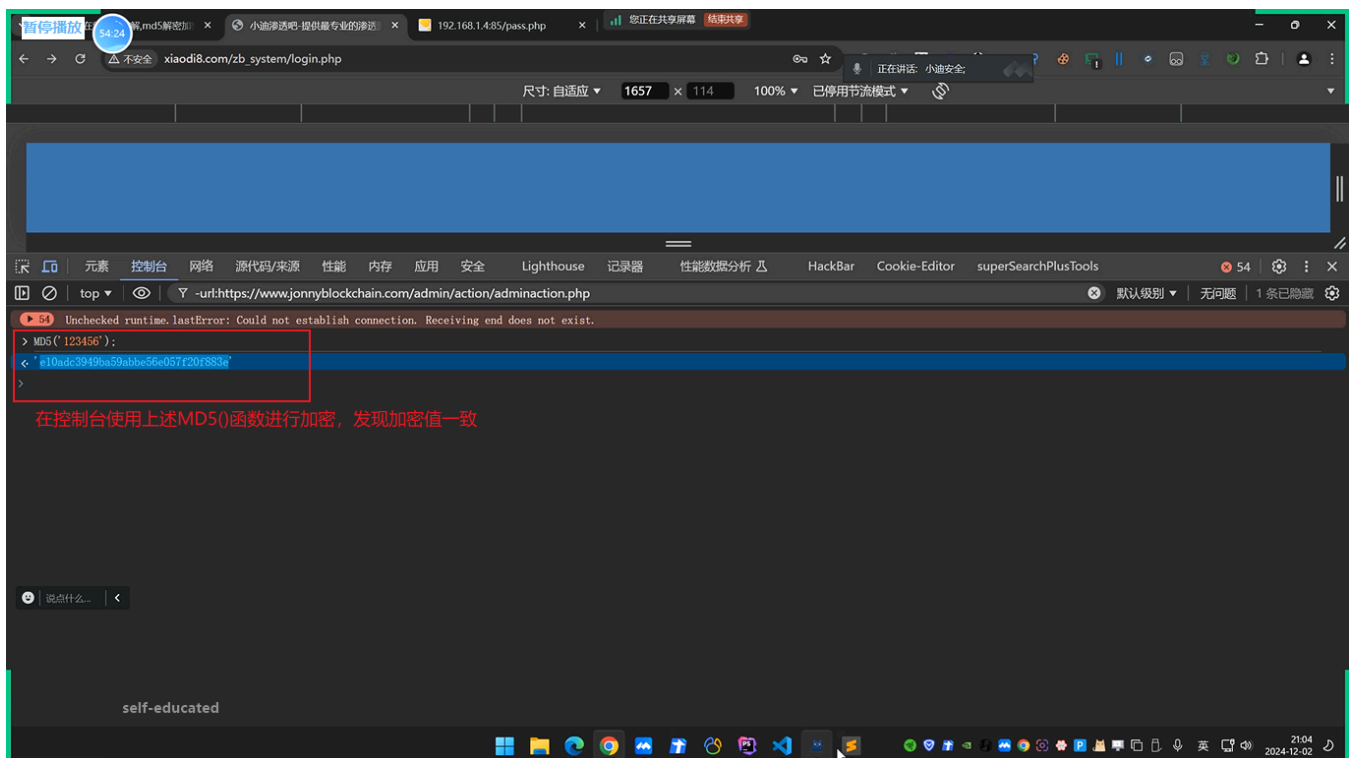
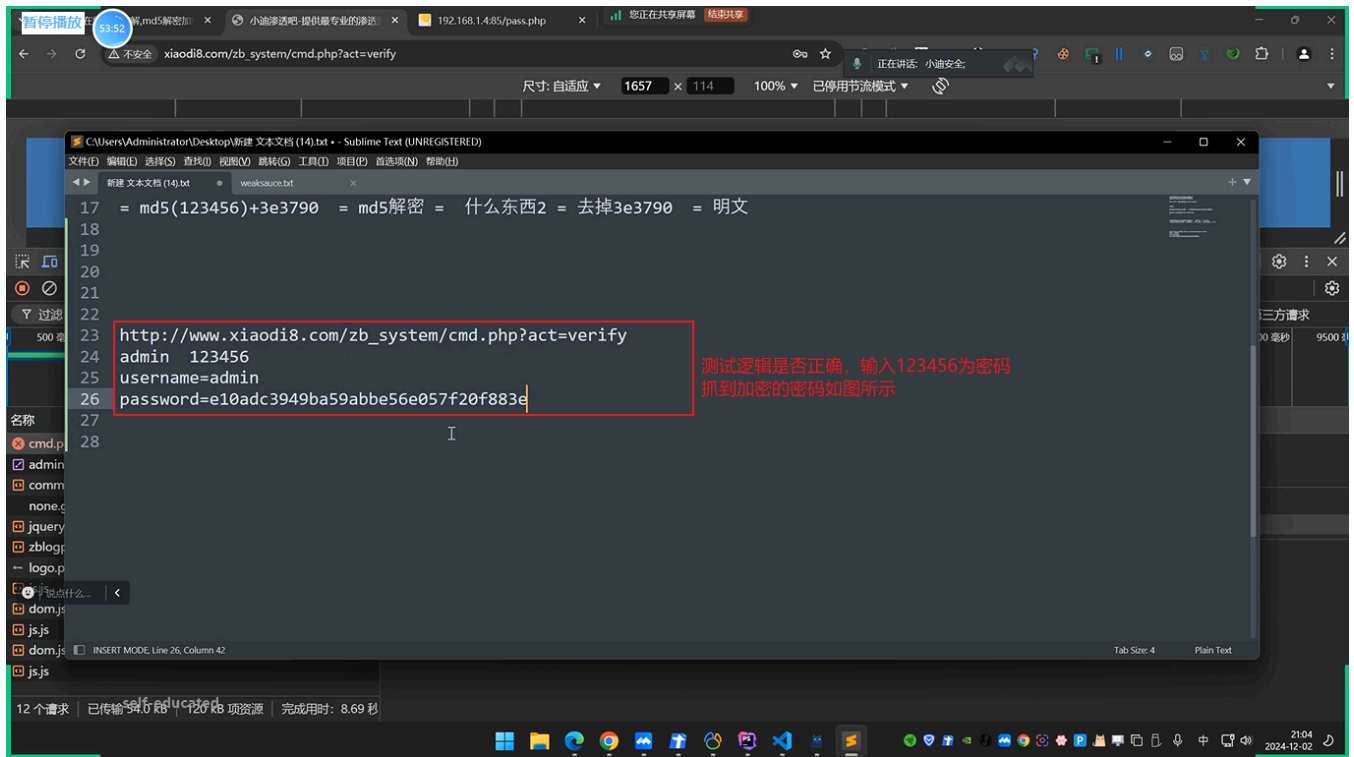
3.1.2 无源码JS逆向

```
1 -博客登录-zblog (前端处理)
2 <script src="script/md5.js" type="text/javascript"></script>
3 $("#btnPost").click(function(){
4     var strPassword=$("#edtPassword").val();
5     $("form").attr("action","cmd.php?act=verify");
6     $("#password").val(MD5(strPassword));
7     console.log(MD5("123456"));
```

```
8
9 -博客登录-混合加密（前端处理）
10 <script src="/Scripts/Vip/Login.js?v=20241202154949"></script>
11 function Login() {
12     logindata.UserName = encodeURI(encrypt.encrypt(numMobile));
13     logindata.Mobile = encodeURI(encrypt.encrypt(numMobile));
14     logindata.Password = encodeURI(encrypt.encrypt(numPassword));
15 }
16 var encrypt = new JSEncrypt();
17 encodeURI(encrypt.encrypt('13554365566'));
```

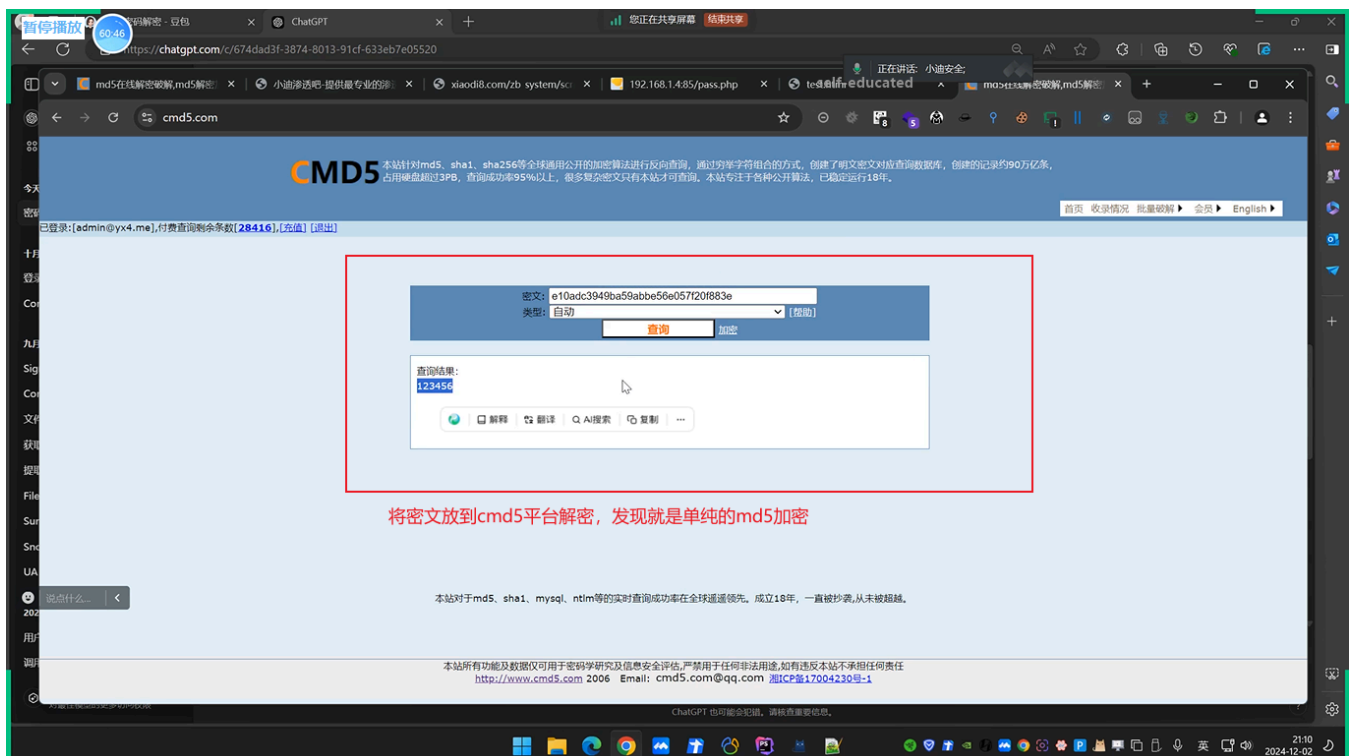






```
1  /* MD5 Message-Digest Algorithm - JavaScript      self-educated
2  ' MODIFICATION HISTORY:
3  ' 1.0 16-Feb-2001 - Phil Fresle (sales@frez.co.uk) - Initial Version (VB/ASP code)
4  ' 1.0 21-Feb-2001 - Enrico Mosanghini (erik504@yahoo.com) - JavaScript porting
5  */
6  function MD5(sMessage)
7  {
8      function RotateLeft(lValue, iShiftBits)
9      {
10         return (lValue << iShiftBits) | (lValue >>> (32-iShiftBits)); }
11     function AddUnsigned(lX,lY)
12     {
13         var lX4,lY4,lX8,lY8,lResult;
14         lX8 = (lX & 0x80000000);
15         lY8 = (lY & 0x80000000);
16         lX4 = (lX & 0x40000000);
17         lY4 = (lY & 0x40000000);
18         lResult = (lX & 0x3FFFFFFF)+(lY & 0x3FFFFFFF);
19         if (lX4 & lY4) {
20             return (lResult ^ 0x80000000 ^ lX8 ^ lY8);
21         }
22         if (lX4 | lY4) {
23             if (lResult & 0x40000000) {
24                 return (lResult ^ 0xC0000000 ^ lX8 ^ lY8);
25             }
26         }
27     }
28     /* ... (rest of the code) ...
length: 7,286 lines: 179 Ln: 9 Col: 6 Sel: 261 | 8 Windows (CR LF) UTF-8 INS
```

将网站加载的md5.js文件下载到本地



将密文放到cmd5平台解密，发现就是单纯的md5加密

3.1.3 明确AES/DES/RSA解密条件

- 1 明确以下三种加密算法加解密条件
- 2 对称AES/DES加解密，非对称RSA加解密
- 3 解密: <http://tool.chacuo.net/cryptdes>

md5解密 | 小油渗透吧-提供专业的渗透 | xiaodib.com/zh-system/scripts | 您正在共享屏幕 | 结束共享

尺寸: 自适应 1657 x 314 100% 已停用节流模式

13554365566

以申通网站为例, 输入账号密码抓取数据包

忘记密码?

扫码关注申通微信公众号

登录

登录后即表示您已阅读并同意申通《隐私政策》|《服务政策》

还没有申通账号? 立即注册

元素 控制台 网络 源代码/来源 性能 内存 应用 安全 Lighthouse 记录器 性能数据分析 HackBar Cookie-Editor superSearchPlusTools

过滤 反转 隐藏数据网址 隐藏扩展程序网址 全部 Fetch/XHR 文档 CSS JS 字体 图片 媒体 清单 WS Wasm 其他 被屏蔽的响应 Cookie 被屏蔽的请求 第三方请求

500 毫秒 1000 毫秒 1500 毫秒 2000 毫秒 2500 毫秒 3000 毫秒 3500 毫秒 4000 毫秒 4500 毫秒 5000 毫秒 5500 毫秒 6000 毫秒 6500 毫秒 7000 毫秒 7500 毫秒 8000 毫秒 8500 毫秒 9000 毫秒 9500 毫秒

名称	状态	类型	启动器	大小	时间
js	200	script		1.3 kB	1 毫秒
js.js	200	script		1.3 kB	1 毫秒
dom.js	200	script		2.0 kB	1 毫秒
mysto.cn	200	document	其他	3.0 kB	181 毫秒
userLoginAndReg.css	200	stylesheet	(索引) -9	2.1 kB	187 毫秒

39 个请求 | 已传输 758 kB | 1.7 MB 项资源 | 完成用时: 7.20 秒 | DOMContentLoaded: 741 毫秒 | 加载时间: 1.37 秒

21:12 2024-12-02

暂停播放 | md5解密 | 小油渗透吧-提供专业的渗透 | xiaodib.com/zh-system/scripts | 您正在共享屏幕 | 结束共享

尺寸: 自适应 1657 x 89 100% 已停用节流模式

13554365566

元素 控制台 网络 源代码/来源 性能 内存 应用 安全 Lighthouse 记录器 性能数据分析 HackBar Cookie-Editor superSearchPlusTools

过滤 反转 隐藏数据网址 隐藏扩展程序网址 全部 Fetch/XHR 文档 CSS JS 字体 图片 媒体 清单 WS Wasm 其他 被屏蔽的响应 Cookie 被屏蔽的请求 第三方请求

1000 毫秒 2000 毫秒 3000 毫秒 4000 毫秒 5000 毫秒 6000 毫秒 7000 毫秒 8000 毫秒 9000 毫秒 10000 毫秒 11000 毫秒 12000 毫秒 13000 毫秒 14000 毫秒 15000 毫秒

名称	状态	类型	启动器	大小	时间
tsp.1.1?code=13&msg=%3Dnc_1_nocaptcha%3Dnc_1_wr...	200	document		3.0 kB	181 毫秒
et_fjs	200	script		1.3 kB	1 毫秒
collina.js	200	script		1.3 kB	1 毫秒
um.js	200	script		2.0 kB	1 毫秒
layer.css?v=3.0.3303	200	stylesheet		2.1 kB	187 毫秒
um.json	200	document		3.0 kB	181 毫秒
favicon.ico	200	image		1.3 kB	1 毫秒
js.js	200	script		1.3 kB	1 毫秒
dom.js	200	script		2.0 kB	1 毫秒
js.js	200	script		1.3 kB	1 毫秒
LoginResult	200	document		3.0 kB	181 毫秒
icon.png	200	image		1.3 kB	1 毫秒

41 个请求 | 已传输 770 kB | 1.8 MB 项资源 | 完成用时: 13.35 秒

21:12 2024-12-02

发现输入的内容做了加密处理

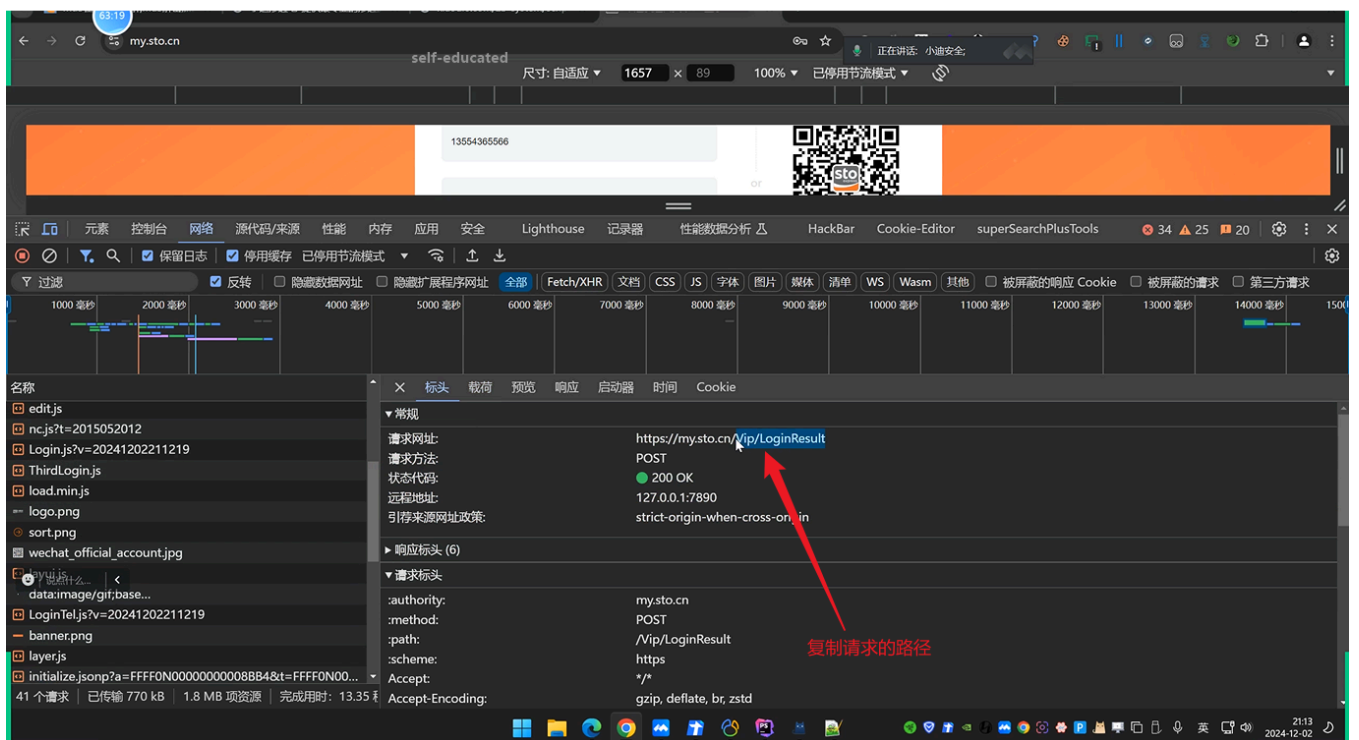
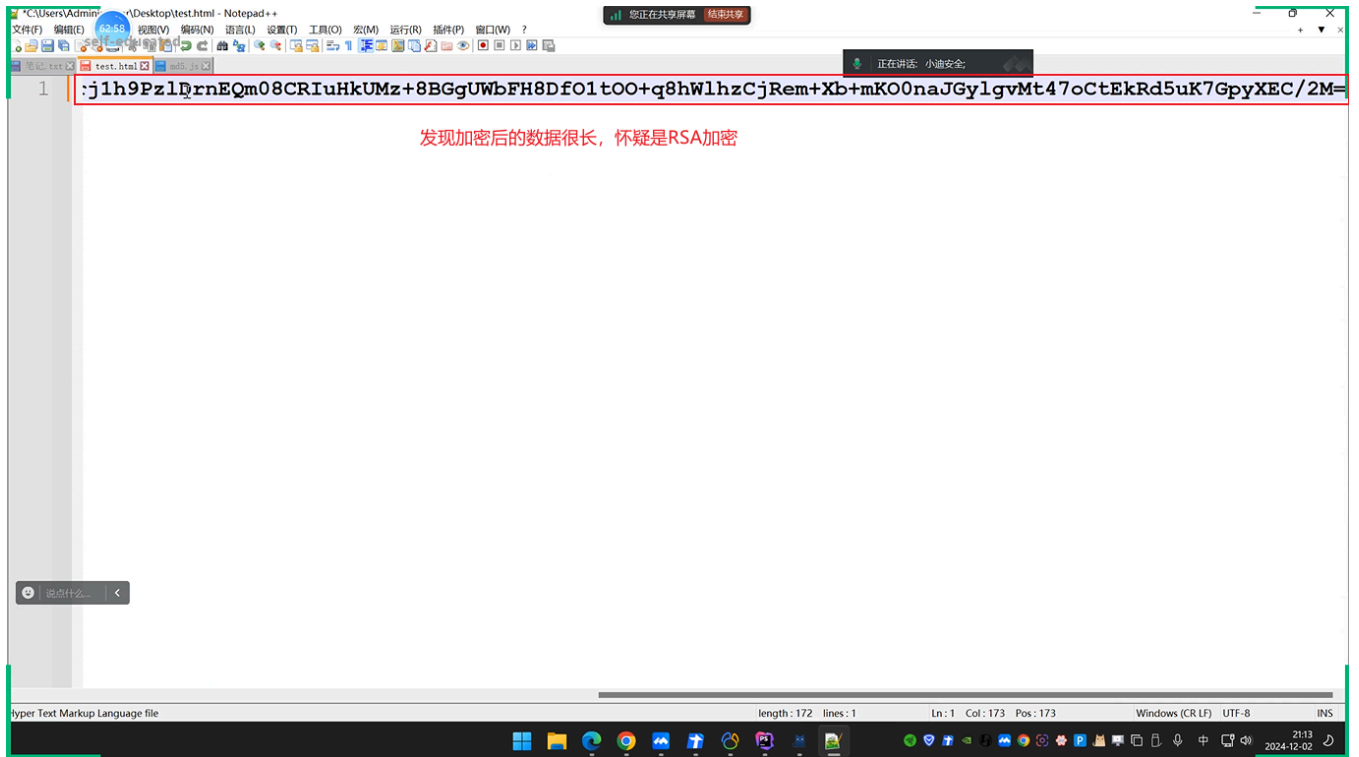
表头 载荷 预览 响应 启动器 时间 Cookie

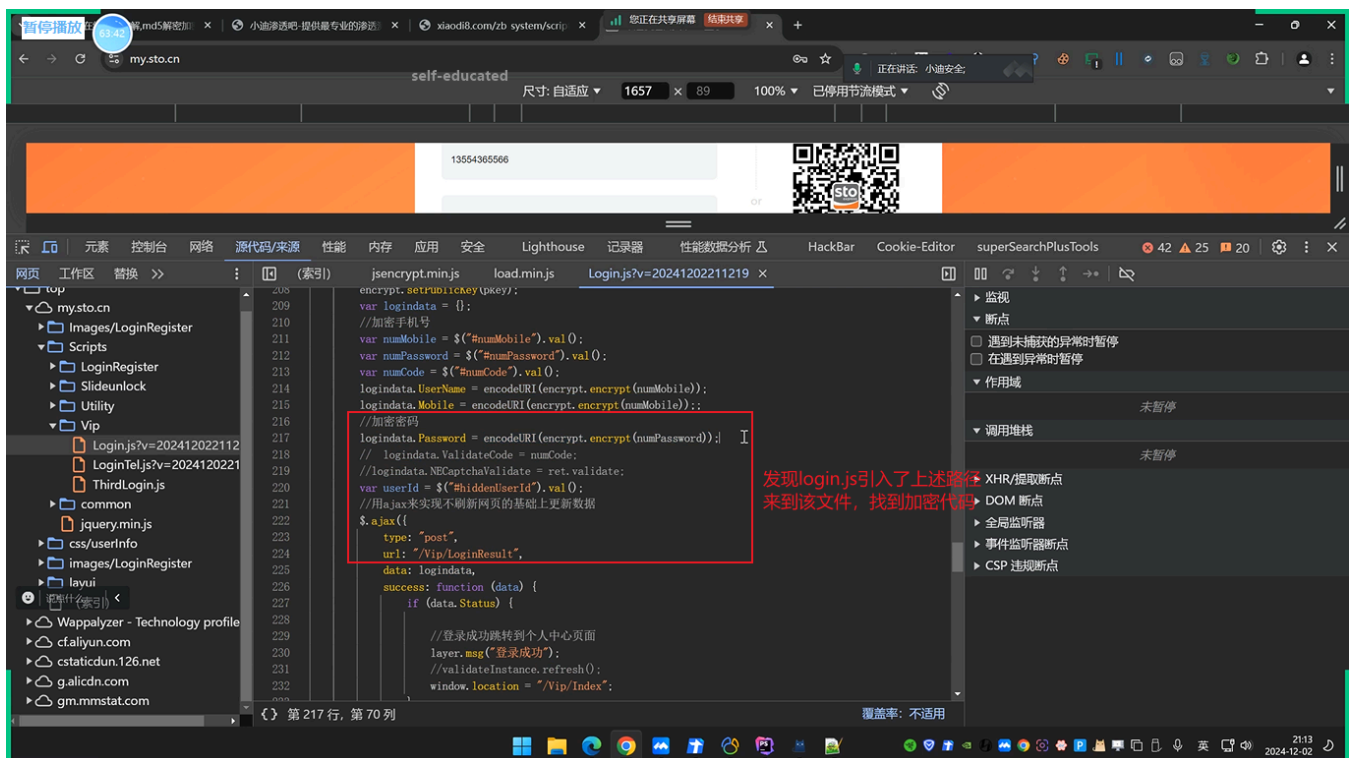
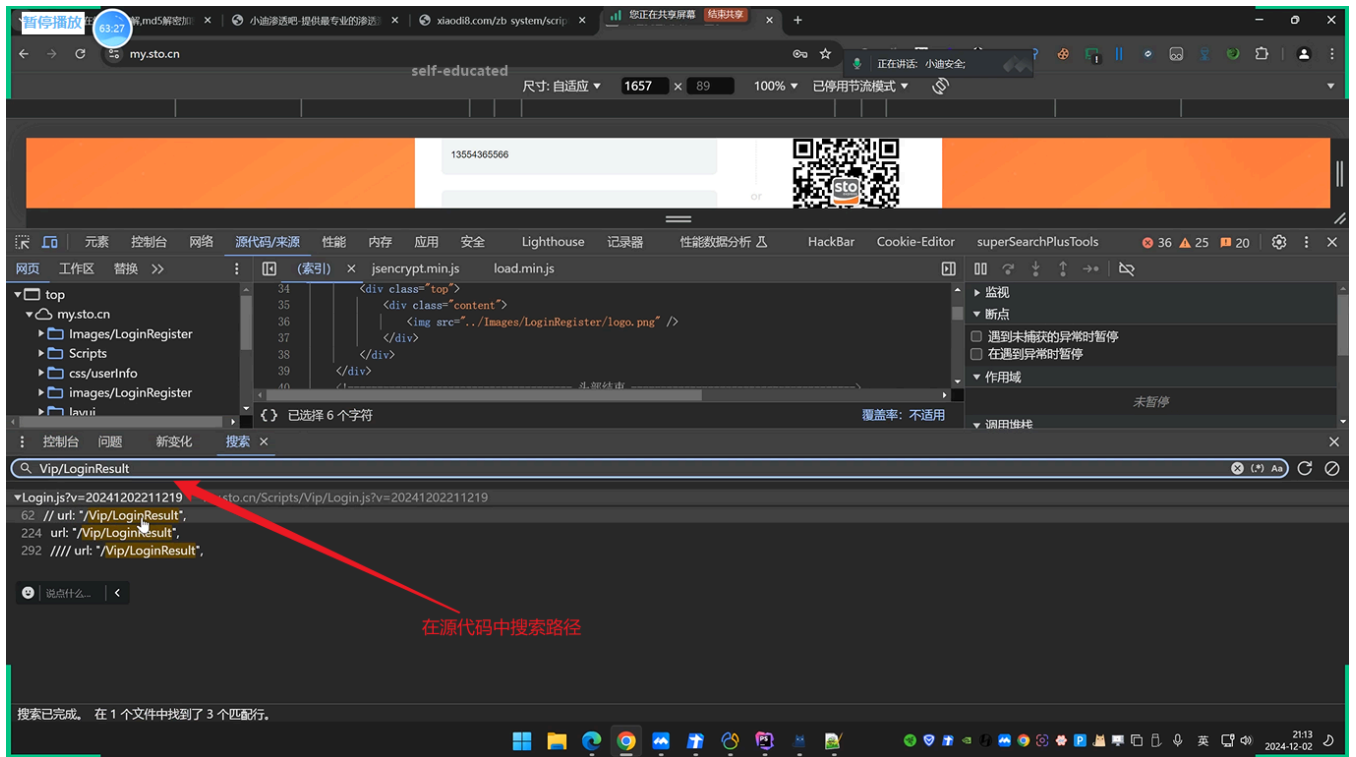
▼ 表头数据 查看源代码 查看网址编码格式的数据

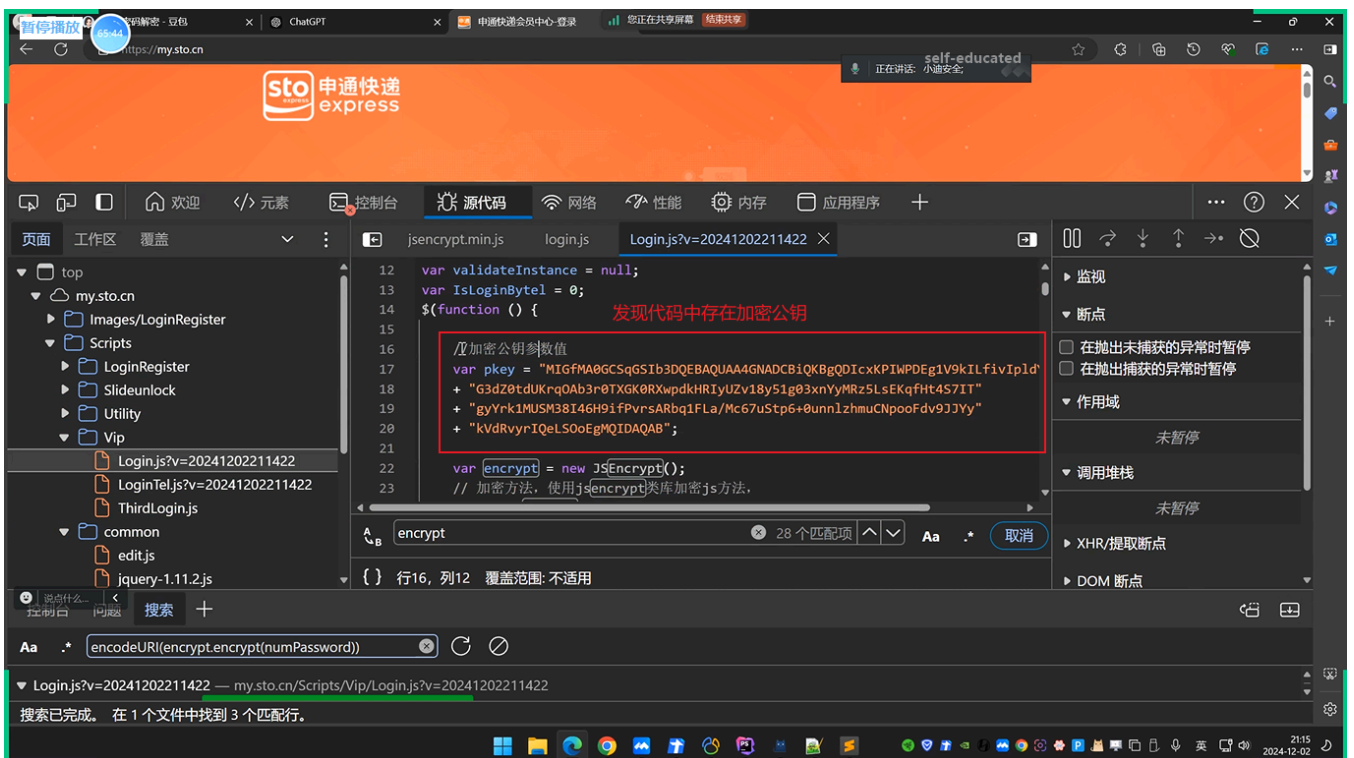
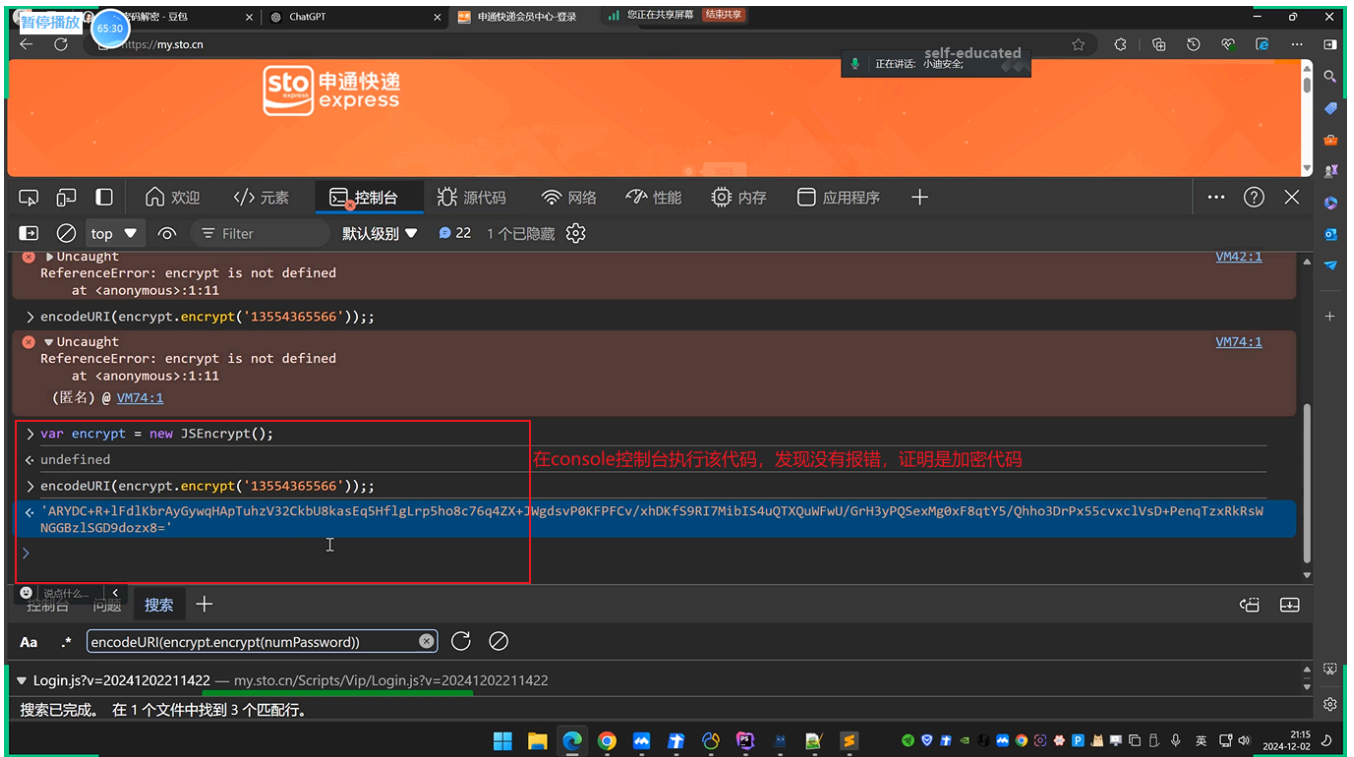
UserName: TpfZ1L2RACD63zb+4uyMtb4EWg1NEdr iCe0 jWQ5 jJhtSRN1d3E1rByNckmz8x8eUR06fEiRrv6tb3JPen8T9M87JNakBd5j7tUDC1Wvf1n1Ghd9T/29clwXLhg/ofB11fecY0z51cPw63oi/SeCreZ0R3uSn4Xawq1/zwC4bg=

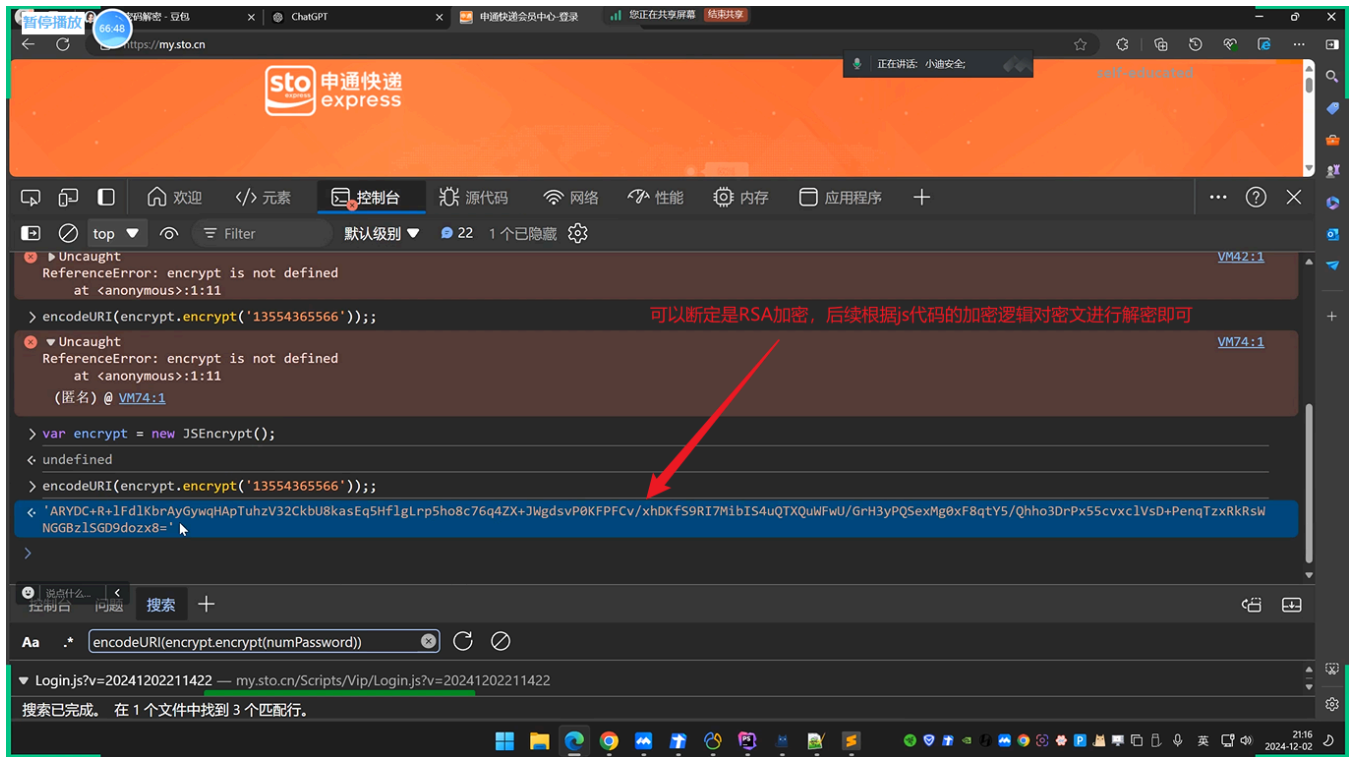
Mobile: MDGbJX+/CLaiXcUTY6v8vfyNdxFBCd7q911LPjd2ISuXJRTab3AuworwPqX0f6T5en54quvJKIPorj1h9Pz1DrnEQo08CR1uHkUmz+8BBGtWbF8BDF01tOO+q8hW1hzCjRem+Xb+mX00naJGylgvMt:47oCtBkRd5uk7GpyXEC/2M=

Password: SDaFMs89/7uAv15lkawwqjv1WQCybjeOMGFzT800ffebk+U6kBSWMS9450T+4TdFMM101m/L13IUt1Z3Df7UZAG7cMKiAS5aqQ1F/OTNav11MuJ5NuBR9IytZ0UP2FFx0AaY1EUTRIGWHzZT03KU1rmbi+Bd132ZWukj4NM=









3.3 总结

- 1 应用场景：
 - 2 1、发送数据的时候自动将数据加密发送（自需加密即可）
 - 3 安全测试思路：我们需要将我们的Payload也要加密发送过去，这样才符合正常的业务逻辑，所以我们就只需要调用应用的JS加密逻辑进行提交发送测试即可！
 - 4 2、比如要得到数据的明文（必须要拿到解密算法）
 - 5 由于各种算法的解密条件不一，密钥，偏移量，私钥等不一定能拿到。
- 6
- 7 对于后续安全测试影响较大的：
 - 8 1、目标：API接口 前后端分离应用居多
 - 9 2、漏洞发现：未授权 各类漏洞测试 爆破等
- 10 3、其他